

Four Ways to Forge a Bundle My Own Verifier Calls Clean

Refusal-Site Mutation Testing of an Evidence-Bundle Verifier

Erik Hill
Independent Researcher
erik@erikhill.dev
ORCID 0009-0002-5912-967X
<https://erikhill.dev>

18 August 2026

Abstract

I built a protocol whose premise is that a stranger can re-run my claims offline and get the same answer. An outside engineer audited it and broke it: a bundle whose headline numbers were false verified clean, the cheapest forgery four bytes. I merged his fix, then pointed my own instruments at the fixed verifier and found the same defect four more times, in places his audit did not reach. The cheapest is one capital letter.

The unifying defect is not cryptographic or exotic: a check that reports success along a path where it never examined anything. *Vacuous pass* is a working label, not a discovery; Section 4 names the literatures already occupying it.

So I stopped collecting anecdotes and measured. At `f59fb62`, under the extraction rule of Section 6, the verifier exposes 112 refusal sites; 75 could be deleted with the whole suite and every tamper fixture still green, a score of 0.330. Three of the four hand-found forgeries fall in surviving classes; the fourth is an obligation with no refusal site. Scored alone, the sixteen-fixture corpus built to prove the verifier can refuse catches 10. Testing the refusals themselves took it to 0.941, then to 1.000 at `92e4548` over a grown population of 146 sites; those denominators differ and the series between them is non-monotone, so Section 7.5 carries all eleven, not just the five rows of Table 2. Fixing the four found defects instead moved 37/112 to 39/119, leaving the pre-existing sites at 37.

Seven times during this study my own measuring tools reported success while measuring nothing; four were built to detect this class, and one returned a perfect 1.000.

Every number here is self-measured on a system I wrote, over a registry that is a closed loop of my own repositories; the one external data point is the audit of Section 2.2. That is stated here rather than buried: it is the paper’s credibility, not a caveat.

Keywords: mutation testing; test oracles; vacuous pass; fail-open validation; software supply chain; attestation verifiers; refusal-site liveness; evidence bundles; reproducibility.

1 Introduction

A verifier is a grader. Its output is a verdict that other people act on. When it accepts, the thing it accepted is copied into a public registry and rendered on a published page. So the interesting question about a verifier is not whether it accepts good input. It is whether its refusals can fire at all.

This paper is a case study of one verifier: mine. It began when an outside engineer submitted a bundle whose headline numbers were false, with every hash pinned honestly, and my verifier printed

structural verification: PASS. The recomputation had run over an empty artifact, found no mismatch, and passed. The forgery cost four bytes.

I merged the fix. Then I asked a narrower question than “are there other bugs”: how much of this verifier’s acceptance logic has ever been observed rejecting anything? To answer it I disabled the verifier’s refusal statements one at a time and asked whether the test suite, a liveness control, or a committed corpus of tampered bundles noticed. Two thirds of them could be deleted with everything still green.

Research questions

RQ1 What fraction of the verifier’s refusal sites can be deleted with the full unit suite, the liveness control, and the committed tamper corpus all still green?

RQ2 Does regression testing the specific defects an external audit found improve that fraction?

RQ3 Does systematic per-refusal liveness testing improve it?

RQ4 Does the operator’s classification of surviving refusals anticipate forgeries found independently by hand?

Every one of these has a measured answer, and one of them is a null result I would not have predicted.

Contributions

1. A reproducible case study of five fail-open and vacuous-pass classes in an offline evidence-bundle verifier, each with a working forgery: the four in Section 5, found against a verifier that had already been hardened once, plus the null-artifact forgery in Section 2.2 reported by the external audit.
2. A refusal-site liveness instrument: a deletion operator applied to an enumerated population of the verifier’s own refusal statements, scored by a deterministic two-detector kill predicate, with an explicit exclusion set and a validity gate. Its operator, its purpose and its precondition each have a published parent. Deleting the statement that signals rejection is Kumar et al.’s; grading a checker by mutation is muSE’s, MASC’s, Chen and Furia’s and, concurrently, Delcourt et al.’s; the green-baseline precondition is standard mutation-tool behaviour. What is offered is the pairing set out in Sections 4.5 and 4.8: the site selection and the subject, applied to the checker’s own source rather than to the artifact it reads. The kill predicate is what makes the measurement decomposable, not what makes it new.
3. An empirical before-and-after on one real verifier, comparing discovered-bug regression testing against systematic refusal-site liveness testing. The first moved coverage from 37/112 to 39/119 and left the caught set on the pre-existing sites at exactly 37. The second moved it to 112/119. The two arms are not effort-matched, the second is measured on top of the first rather than as an alternative to it, and Section 7.5 states why the second arm’s gain is partly entailed by how the intervention is defined. The null result in the first arm was independently anticipated, on a system I did not write, by Bilal and Mughal (Section 4.5).
4. A separately scored detector result. The committed corpus of tampered bundles, written for the express purpose of proving the verifier can refuse, catches 10 of 112 refusal sites on its own, against a structural ceiling of 16/112 that no amount of care in writing those sixteen

fixtures could beat (Section 7.1). MASC reports the same shape of result from the other side of the pipeline, and Section 4.8 sets out how the two partitions differ.

5. A finding-shaped hypothesis, untested outside this codebase, that an evidence artifact emitted as a report is systematically underbound relative to one consumed as a check's input (Section 7.6). The narrower form, keyed to whether the artifact is human-readable, is refuted there by this paper's own data at $n = 4$.
6. Seven documented cases in which the measuring instruments reported success while measuring nothing (Section 9), including one that returned a perfect score. None of the three closest neighbouring papers reports an instrument of its own returning a passing verdict along a path where it performed no comparison, although MASC reports exactly that of the detectors it was measuring (Section 4.5).

Section 11 states exactly what is and is not claimed, and Section 12 states what could make each claim wrong. The short version is in the abstract and is worth repeating: this is $n = 1$, self-measured, on a registry of my own repositories.

A note on numbers and commits

Line numbers and counts in a live repository are claims with a short shelf life, and an earlier draft of this paper went stale by citing two of them. Every file and line citation below is therefore pinned to a commit. The pre-fix baseline is `f59fb62`; two citations in Section 13 resolve at `27809ce`; present-day figures are measured at `92e4548`, the commit named in the Reproducibility and artifacts section. That section is unnumbered, so it is named rather than cross-referenced.

2 The system under study

2.1 The instrument and the claim

VAC (Verifiable Agent Claims) is an evidence-bundle format plus an offline verifier. A bundle pins every artifact by sha256, declares headline numbers in `results.summary`, and declares `results.checks` that bind those numbers to recomputable quantities inside the artifacts. On success the verifier prints:

```
structural verification: PASS (valid)
  proved offline: manifest schema, artifact presence + sha256, bundle closure,
  stated limitations, stamp agreement, declared results recomputed from artifacts.
```

That last clause is the load-bearing one. Everything in this paper is an attack on it.

Accepted bundles are copied into a public registry (`vac/registry.py:171` copies `results.summary` verbatim) and rendered on a published page (`index.html:113`). Both citations resolve unchanged at `f59fb62` and at `92e4548`. A lie that survives the verifier is not academic; it is published.

The trust boundary is therefore between an issuer, who supplies the bundle, and a reader, who sees the registry. The verifier is the only thing in between. In the vocabulary of RFC 9334 [8], the verifier appraises evidence against an appraisal policy and produces a result that a relying party consumes. What that architecture does not specify, and what this paper is about, is how anyone establishes that the appraisal policy was actually applied.

2.2 The external audit and the hardening baseline

Giulio D’Erme, author of `cca-audit` (<https://github.com/GiulioDER/cca-audit>), ran a deep audit after I posted an open replay request. Four pull requests came out of it. Two are analysed here, #1 and #2; the other two arrived after the measurements in this paper were taken and are recorded at the end of this section.

His central finding: a bundle declaring `summary.verdicts: 9999` while the artifact held 3, with `evidence/bundle.json` replaced by the four bytes `null` and its sha256 re-pinned honestly. It exited 0 and printed `structural verification: PASS`. The hash binding was intact. The recomputation ran over nothing, found no mismatch, and passed. This is the textbook vacuity example transposed into a verifier: every request is eventually acknowledged, in an environment that never generates requests [53].

That first pull request opened with **eight** bundles that exited 0 under `structural verification: PASS`. Five were false declared numbers, the class the table above describes. The other three were content crossing the bundle boundary and are distinct defects rather than variants: `_safe_relpath` accepting a drive-anchored path, which is an arbitrary read and a content-confirmation oracle; `_bundle_root` counting only directories, so a top-level sibling file rode along and the closure scan never saw it, which is a closure hole of the same class as the symlinks in #8 rather than traversal; and `_extract_tar` accepting Windows-separator and root-anchored members, which is the one that depends on the untested Python window. An earlier draft of this paper said five paths plus path traversal, and attributed the untested-window dependency to the wrong one of the three. The auditor corrected both on 18 August 2026. His second pull request found something worse in kind: no `encoding=` on `read_text` and `write_text`, so the same bytes produced opposite verdicts on a cp1252 host and a UTF-8 host. That is fatal for a protocol whose entire premise is that a stranger gets my answer offline, and it is a bit-for-bit reproducibility failure of exactly the kind the reproducible-builds literature exists to characterise [17, 33].

Two things cut the other way and are worth recording. First, four of his strongest findings were refuted by my own specification rather than by argument: the spec had already decided those cases and said so. His words on that, posted publicly, were “Documentation that refutes an auditor is rarer than the bugs, and I would rate it higher” [15]. He also names the four: unknown severity weighing 0, a score of 1.0 when nothing applied, the floor inequality, and the registry HEAD question. A separate sentence in the pull request body makes the same point: “four findings refuted by documentation rather than by argument is not the usual experience reading someone’s spec” [16].

A draft of this paper carried a footnote asserting that the first of those two sentences was my own compression and that he had not written it. That footnote was wrong, and wrong in the direction that matters: it credited me with his sentence. It was introduced by a pre-publication audit that checked the pull request body, found the second sentence there, and inferred the first was fabricated. He wrote both, in different places, and corrected the record himself. The episode is left visible here because a paper about checks that pass without checking should not hide the one instance it committed against a named third party, and because the failure has a shape worth naming: a correction is a new claim, and it needs the same evidence the original did.

Second, my `RESULTS.md` byte-identity check caught mojibake in his own output mid-review. The instrument worked on the auditor. That is checkable too: he reports it in the same public comment, saying he fetched the source with a locale decode, mojibaked every section sign and dash in the file, and that the byte-identity check caught it immediately [15]. An earlier draft called this a first-person report resting on no public artifact. It rests on the same artifact as the quote.

Everything in Section 5 runs against `main` at `f59fb62`, *after* that soundness fix. That is what

makes the four findings interesting rather than routine: they survived an external audit and its remediation.

The audit did not stop with those two pull requests, and this record should not either. On 18 August 2026, after the hardening described above and after every present-day figure in this paper was measured, the same auditor filed two more. Pull request #9 (<https://github.com/egnaro9/vac-protocol/pull/9>) reports that a default Git for Windows clone rewrites the repository’s text artifacts to CRLF, so the sha256 pins in an honest bundle stop matching; it changes only `.gitattributes` and a test, and it is merged at 81f50cf, after the commit the figures below are pinned to. Pull request #8 (<https://github.com/egnaro9/vac-protocol/pull/8>) is the one that belongs to this paper’s class, and it is open.

Its second case, E2 in that pull request’s own table of reproductions, is a fifth vacuous pass against the hardened verifier: the four of Section 5 plus this one, found after them. It is deliberately not folded into the five classes this paper claims (Section 11, item 1), which are those four plus the auditor’s `null-artifact` case against the pre-hardening version. Replace a covered artifact with a symlink whose target sits outside the bundle, and the verifier exits 0 and prints **structural verification: PASS**, banner clause **bundle closure** included. The bytes hash identically because they are the same bytes; they simply live somewhere else on the verifying host. I reproduced it at 92e4548, the commit this paper’s present-day figures are measured at, with controls in both directions: an unlisted file placed directly in the bundle is refused (**unlisted-file**), one byte appended to a covered artifact is refused (**sha256-mismatch**), the symlinked artifact passes, and removing the out-of-bundle target turns the same bundle into **missing-artifact**. That last control is why it is recorded as a vacuous pass and not as a fifth forgery: it is host-dependent, and a stranger replaying the bundle without the target file present gets a refusal, so the four of the title stand. The mechanism is one line, `vac/verify.py:224` at 92e4548: the closure scan is `rglob` filtered by `is_file()`, and `rglob` does not descend a symlinked directory while `is_file()` follows a symlinked file. The pull request’s first case is the other half of that same line: an unlisted file placed inside a symlinked subdirectory is never seen at all, and the run exits 0 naming nothing, where the same file placed directly in the bundle is refused.

That pull request is open and is deliberately not landed before this paper. Its own commit adds two refusal statements to `vac/verify.py`, which moves the population every number in Section 7 is scored against: 146 raw refusal sites at 92e4548, 153 at the pull request’s parent, which is #2, and 155 at its own head. Landing it would invalidate the figures rather than update them, so it is recorded here as an open finding against the fixed verifier and left for the next measurement round. A check that prints **bundle closure** while reading evidence from outside the bundle is the same shape as everything in Section 5, which is the point worth stating plainly: the class kept being findable after I started writing about it, and the person who found it again was the auditor, not the author.

3 The class: a check that cannot fail

3.1 Definition

Every finding in this paper is an instance of one shape.

A gate reports success along a path where it never examined the thing it claims to examine. The pass is real. The checking never happened.

Definition 1 (Vacuous pass) *A verifier exhibits a vacuous pass when it returns acceptance while*

an intended binding, comparison, or coverage obligation was absent, bypassed, or semantically unexamined.

The common ancestor is an absence-assertion with no liveness proof. “Nothing bad was found” is meaningful only if you have separately established that the detector *can* fire.

The weakness taxonomy already has vocabulary for the parts. CWE-703 is the pillar, improper check or handling of exceptional conditions [41]; CWE-754 covers the plain unchecked case and, by its own scope note, is not restricted to exception handling [42]; CWE-636 names the design decision to fall back to a less secure state, with the alternate term “failing open” [40]; CWE-390 is the tightest fit for the instrument failures in Section 9, where an error condition was detected and converted into a success signal [39]. Section 5.1 concerns consistency between fields of one complex input, which is CWE-1288 [38]. Having the names is a convenience, not a result. It does mean the class is standard rather than idiosyncratic.

3.2 The same shape elsewhere

I have hit this shape repeatedly in work that had nothing to do with this protocol. These are the author’s own observations, offered as motivation rather than as data:

- a determinism test that compared two runs of the *same* runtime stayed green through a 69-diff cross-runtime divergence;
- a health endpoint returned 200 while the real code path was dead;
- a shell gate of the form `... | grep "Tests "` matched the tally line whether the tests passed or failed;
- a test that sampled an *animating* value passed against the very bug it targeted.

The published record contains the industrial-scale version. Certificate validation was broken across payment SDKs, e-commerce platforms, and web-services middleware, with badly designed APIs diagnosed as the root cause [18]. A production attestation verifier, **cosign**, reported a false positive for `verify-attestation --type` when at least one attestation carried a valid signature *and* no attestation of the requested type was present: CVE-2022-35929 [52]. Both conditions are necessary, and the advisory states them as a conjunction; the second is the one that makes it this paper’s shape. That last one deserves emphasis, because it is the closest external corroboration this paper has. It is the same shape as Section 5.4, in somebody else’s verifier, with a CVE attached. The mechanisms differ: **cosign** applies a type filter to the wrong subject, while Section 5.4 skips a comparison guarded on operand existence. What is shared is an obligation over an absent subject discharged as success, with the party supplying the input deciding the absence.

4 Related work

The draft of this paper that circulated privately said only that “the territory is already occupied” and named no occupants. This section names them, and in three places the literature narrows what I can claim.

4.1 Vacuity and sanity checking

Vacuity detection asks whether a property was satisfied trivially. Beer et al. introduced it after observing that implications can be satisfied by antecedent failure, and reported from IBM hardware-verification practice that during first formal verification runs “typically 20% of formulas are found to be trivially valid, and that trivial validity always points to a real problem in either the design or its specification or environment” [5]. Kupferman and Vardi extended subformula-replacement vacuity from the ACTL fragment to CTL* [31]. Kupferman’s survey frames the whole family as *sanity checks*, motivated by the observation that “when the answer to the correctness query is positive, most model-checking tools provide no additional information”, and argues that vacuity and coverage “are essentially the same: both are based on repeating the verification process on some mutant input” [30]. Simmonds et al. supply the canonical illustration: a property that every request is eventually acknowledged is satisfied in an environment that never generates requests [53].

The shape is the same as mine. The mechanism is not, and I want to be exact about the difference rather than borrow the formalism. Vacuity in model checking is a property of a specification relative to a model, decided by replacing subformulas. A vacuous pass here is a verifier whose code path returns acceptance without executing a comparison. This paper does not instantiate Beer et al.’s formal definition, and it should not be read as claiming to. What it borrows is the framing: a positive answer is the thing that needs a further automatic check. The 20% figure is also the closest published precedent for the shape of my own baseline result, and it is an independent industrial measurement rather than a self-report.

4.2 The oracle problem and oracle adequacy

Weyuker named the assumption that a tester or external mechanism can decide whether output is correct, and the programs for which it fails [59]. Barr et al. survey the resulting problem and give the formalism this paper needs: the ground truth is a conceptual oracle that always gives the right answer, unknowable in all but trivial cases, against which real oracles are sound or complete only in part [4]. Their category of *implicit* oracles, built on general anomaly detection such as abnormal termination, names exactly what several of my instruments were doing while claiming to be specified oracles: a sweep that scored “nonzero exit” as “correctly refused” (Section 9) was running on an implicit oracle and reporting a specified one.

Oracle quality has been measured directly. Schuler and Zeller’s checked coverage measures the fraction of executed statements that actually influence an oracle, motivated by a parser with 83% statement coverage in which “none of the parsed results is actually checked for any property” [50, 51]. Their internal-validity paragraph carries the warning this paper should read against itself: “even programs without oracles can still achieve a high mutation score by relying on uncontrolled implicit checks”. Huo and Clause measure the same phenomenon from the other side, detecting brittle assertions and *unused inputs*, inputs provided by a test that no assertion checks [21]; that is the closest published analogue to the closure rule in Section 5.2, where an evidence artifact covered by no check becomes a named refusal. Jahangirova et al. use mutation to expose oracle false negatives and then *improve* the oracle [25], which is methodologically what Section 7.5 does: one test per surviving refusal, so the gate is asserted rather than merely executed.

On coverage as a proxy, Inozemtseva and Holmes generated 31,000 suites over five systems and found only a low to moderate correlation between coverage and effectiveness once suite size is controlled, concluding that coverage “should not be used as a quality target” [24]. Their effectiveness measure is itself the mutation score, which is worth stating plainly rather than citing them as evidence that mutation works. Zhang and Mesbah composed 6,700 suites from 24,000 assertions and

found assertion count and assertion coverage strongly correlated with effectiveness [61]; their introduction states the thesis of my Section 7.5 directly, that coverage without checking for correctness is meaningless.

4.3 Mutation testing and statement deletion

Mutation analysis originates with Hamlet [20] and DeMillo, Lipton and Sayward [13]. Budd et al. treat mutation as an *adequacy* criterion on test data rather than a correctness argument [10], and Zhu, Hall and May’s survey establishes adequacy as the formal category a mutation score belongs to [63]. That distinction is what licenses the careful reading of my own 1.000 in Section 12.1. The surveys by Jia and Harman [27] and Papadakis et al. [46] are the reference points for the method as an experimental discipline. Just et al. supply the validity argument and its ceiling: across 357 real faults in five applications, mutant detection correlates with real fault detection independently of coverage, 73% of real faults are coupled to mutants generated by common operators, and 17% are coupled to no mutant at all [28]. Their finding that statement deletion is one of the three operators most often coupled to real faults is what turns my choice of a deletion operator from an ad hoc script into a defensible one. Petrović and Ivanković report mutation at Google, including the practice of excluding “arid” lines explicitly rather than counting them as caught [47], which is the industrial precedent for the exclusion set in Section 6.3.

The operator itself is not new, and this is the first place the literature narrows my claim. Untch proposed statement deletion (SDL) as a single sufficient mutagenic operator [57], and Deng, Offutt and Li evaluated it empirically [14]. Deleting error-handling specifically is also published: Ji et al. define a catch-block deletion operator [26], and Kumar et al. define throw-statement deletion, which removes the sole statement by which a program signals rejection and asks whether any test fails [29]. That is structurally identical to replacing a refusal statement with `pass`. Loise et al. introduce fifteen security-aware operators for Java and report that standard operators are unlikely to introduce comparable vulnerabilities [35], which is the published precedent for my claim that a general-purpose mutation run would not have targeted the refusal sites.

Extreme mutation is the second narrowing. Niedermayr et al. delete whole method bodies to find *pseudo-tested* methods, those tested such that faults would not be detected [44], and Vera-Pérez et al. study the phenomenon at scale and report that developers respond by strengthening tests rather than deleting code [58]. An earlier draft of this paper claimed statement granularity as the residual novelty over that work. That is wrong: Maton, Kapfhammer and McMinn published exactly it, using SDL to uncover pseudo-tested *statements*, finding 722 cases across 27 Java projects of which 48% lie outside pseudo-tested methods [37]. Their paper even makes my own argument about tool blind spots, that a popular Java mutation tool would not have mutated some of the statement types involved.

4.4 Mutation pointed at checkers rather than at code under test

A smaller literature points mutation at the checking apparatus. Martin and Xie mutate XACML access-control *policies* [36]. Ami et al.’s muSE uses mutation to discover unsound choices in security-focused Android static analysis [1], and their MASC carries the same idea into crypto-API misuse detection at a scale of 20,303 mutants against nine detectors [2, 3]. Görz et al. extend mutation analysis to grading fuzzers [19]. Chen and Furia perform robustness testing of intermediate verifiers, generating semantically equivalent Boogie programs and finding brittle behaviour in 16 of 135 [11]. Lipp et al. supply the external calibration a reader should apply to my 0.330: state-of-the-art static C analyzers miss between 47% and 80% of vulnerabilities in a benchmark of real programs [34].

The direction matters and I state it rather than leave a reviewer to find it. muSE, MASC, Görz et al., Delcourt et al. and Chen and Furia all mutate the checker’s *input*, seeding defects into the artifact under analysis and asking whether the checker detects them. Chen and Furia additionally target the opposite failure from mine, false alarms rather than false passes. This paper mutates the checker’s own refusal statements. Similarly, the existing mutation-in-continuous-integration literature puts the mutation tool *inside* the pipeline: Örgård et al.’s industrial case study evaluates C++ mutation tools in GitHub Actions workflows and says nothing about mutating a gate [45]. This paper points the mutation tool *at* the gate. That is a different move from grading a checker by mutating what it reads, which is muSE’s, MASC’s and, concurrently, Delcourt et al.’s; Section 4.5 sets out how much of the surrounding ground those three occupy.

4.5 Three close neighbours

Three papers sit close enough to this one to change what I am entitled to claim. One is prior art I should have found earlier: MASC, published at IEEE S&P in 2022. The other two were posted to arXiv while this study was running, on 21 June and 14 August 2026, so they are contemporaneous work rather than literature I failed to search. Neither of those two is in print; one is a preprint submitted to a magazine, the other is accepted at a conference that meets in October 2026. I describe each by what it already owns.

MASC. Ami et al. carry muSE’s idea into crypto-API misuse detection [2, 3]. Twelve usage-based mutation operators, three mutation scopes, and an explicit three-adversary threat model instantiate compilable variants of crypto-API misuse cases, seeded into thirteen Android apps and four Apache Qpid Broker-J subsystems: 20,303 mutants, generated in about fifteen minutes. Nine crypto-detectors were evaluated and 19 unique undocumented flaws found, appearing across those detectors as 76 flaw instances, of which 45 (59.21%) are attributable solely to the mutation approach rather than to base instantiations of the same misuse cases; all flaws in six of the nine detectors were visible only through MASC. The journal extension enlarges this to nineteen operators, 107 misuse cases and five further detectors. MASC belongs in the list above, and its absence from an earlier draft of this paper was an oversight rather than a judgement, particularly since muSE is already cited here. Three of its results bear on mine directly, and a fourth, the base-instantiation comparison of its Step 6, is taken up in Section 4.8.

First, its motivating premise is that hand-curated benchmarks are, in their words, “incomplete, incorrect, and impractical to maintain”, hedged with a *may be* and evidenced by the OWASP benchmark treating AES in ECB mode as secure until 2020 [2]. That is the published form of the structural ceiling I derive in Section 7.1, and the direction of the argument is theirs. The two claims do different work, though. Theirs is empirical and hedged; mine is a bound, since a committed corpus of n fixtures cannot catch more than n of 112 sites however well the n are written. The arithmetic is not a discovery. It is what makes the 10/112 in Section 7.1 interpretable.

Second, their first operator is atypical letter case. Passed to `Cipher.getInstance`, the algorithm name "DES" is flagged by CryptoGuard and "des" is not. The forgery in Section 5.3 costs one capital letter. I keep the instance and withdraw any suggestion that the shape is unreported, because it has been in print since 2022.

Third, and running the other way, before analysing uncaught mutants they found that some detectors “analyze only a limited portion of the target applications”. CryptoGuard and CogniCrypt do not handle multiple dex files, which left CryptoGuard analysing 871 of 2,515 Android mutants until they patched it, and CryptoGuard skips any class whose package name contains `android.` or ends in `android`, which excludes applications such as LastPass and LinkedIn. They group these

under a flaw class zero and exclude them from their counts for a reason they state plainly: “these gaps were not detected using MASC’s evaluation” [2]. A detector returning a clean verdict over code it never read is the shape this paper measures, and mutating the detector’s input did not find it. The mechanism is not identical: theirs is a scope limitation rather than a branch that returns acceptance, and a silent detector reads as clean rather than issuing an explicit verdict. With that caveat, it is the clearest published evidence I have that the two mutation sites answer different questions.

Mutation testing of semantic judges. Delcourt et al. point mutation at LLM-based judges of domain class diagrams [12]. Eleven operators, five rule-based and six LLM-assisted, inject semantic defects into PlantUML class diagrams while leaving the paired textual description unchanged, and each operator also emits a short natural-language description of the defect it injected. A mutant is killed when at least one issue the judge reports reaches cosine similarity $\tau = 0.55$ against that description, the threshold calibrated on 209 hand-labelled judgments to an F1 of 0.90. Across 547 mutants and six judge configurations, 3,282 mutant judgments in total, the kill ratio is 82.4%, and their headline result is that this automated score largely reproduces the ordering a manual precision study produces over the same configurations: Pearson $r = 0.624$, and the same ordering on 11 of the 15 configuration pairs. They read per-operator kill ratios as fault classes the judge misses, and they warn that easy operators inflate the aggregate. This paper makes both of those moves, and neither of us invented them: reading survivors as fault classes the oracle does not detect is textbook mutation testing, and their own background section says so with a citation. What is worth stating plainly is that using a mutation tool to score a grader, and reporting a kill ratio over it, is neither a thin nor an unoccupied idea in 2026, and this paper does not present it as one.

What their eleven operators do not touch is the judge. Every one of them mutates the artifact the judge is asked to judge. Judge variation in their design is configuration selection, three models crossed with two prompts, which they describe as reflecting standard practice in judge development; no operator is applied to a judge’s source, to its prompt text, or to the kill detector, and the similarity threshold is calibrated rather than mutated. Two of their three models are closed-source, so for most of their configurations there is no checking code available to mutate in the first place. Two further differences matter for what each instrument can say. Their failure mode is judge sensitivity, whether a model notices a defect it did in fact look at; a silent judge simply leaves the mutant alive and pays for it in kill ratio. Mine is a path that returns acceptance without examining anything, which has no analogue in their setting. And their kill decision is a calibrated embedding threshold whose transferability across models they name as a threat to validity, where the predicate in Section 6 is exact and machine-decidable, which is the ordinary situation for a mutation tool scored by a unit suite rather than an achievement of this paper. That is a difference in what the two instruments can claim, not a ranking of the two papers.

A green suite that keeps shipping defects. Bilal and Mughal report a production rental-search assistant whose suite reached 1,553 test cases in six weeks, passed continuously, and kept shipping user-facing defects [7]. They classify all 252 bug-fix commits by the boundary, or seam, each defect escaped through, and find 110 of them, 44%, in four seams no component-level test observes: the live browser runtime, the non-default market, the end-to-end flow, and the whole-system level. Their mechanism is substitution. Wherever a component test needs determinism, it replaces the side of the boundary it cannot control with a fixed stand-in, and the seam then goes unobserved entirely, so the count of such tests can rise without limit while the set of conditions the suite ever meets stays where it was. That is the conclusion of Section 8 reached in another domain,

and reached two months before I reached it.

The mechanism differs, and the difference is worth keeping. Their blindness always sits at a boundary where a stand-in took the place of something uncontrolled, and all four of their seams are boundaries. The vacuous pass in Section 7.4 has no boundary in it: the comparison runs to completion, inside one function, over an artifact with nothing in it. What is shared is the conclusion, that adding tests inside the substituted world does not move what gets observed.

One of their incidents is closer still. A quoting error in a client-side component broke a form step, was visible only in a running browser, and shipped twice: the guard left behind by the first fix lived in “the same browser-blind harness that had missed the defect” [7], so it could not see the repeat. That is an external instance of the null result in Section 7.3, reported independently, on a system I did not write. They also record that 107 of 252 fixes touched a test file, and treat that as an upper bound on real regression guards, since a fix that edits a test file has not thereby acquired a test that would catch its own defect again. That is the proxy the kill predicate here exists to replace. Their evidence is broader than mine and shallower. It is observational: they inject no faults, and by their own statement they count the defects they found, so silent escapes are not measured. Nothing in their design can report what fraction of their checks are inert. Nothing in mine generalises past one verifier.

What the three take, and what they leave. Together they remove three things an earlier draft of this paper was implicitly claiming. Using mutation to grade a grader is occupied, at 20,303 mutants in one case and 3,282 judgments in another. Reading surviving mutants as blind spots in the checker, and warning that easy mutants inflate the aggregate, belongs to the mutation-testing literature, and to Delcourt et al. in this setting, before it belongs to me. And a large continuously green suite that keeps shipping defects because of what its checks observe rather than how many there are is Bilal and Mughal’s reported observation, not this paper’s discovery. What none of the three does is modify a line of the checker’s own source: MASC and Delcourt et al. mutate the input, and Bilal and Mughal inject nothing at all. None of the three reports its own measuring apparatus returning a passing verdict along a path where it performed no comparison, which is the material in Section 9, although MASC reports exactly that of the detectors it was measuring. Section 4.8 states what that leaves.

4.6 Supply-chain attestation and verifier soundness

The wider context is machine-readable evidence about software. TUF established that a signature-valid update system can still fail once you look past the cryptography [49]; Sigstore made signing and transparency broadly deployable [43]; reproducible builds argue that trusting code is not the same as trusting its executables [17, 33]; Ladisa et al. taxonomise 107 attack vectors linked to 94 real incidents [32]; and Xia et al. document practitioner experience with software bills of materials from 17 interviews and 65 survey responses [60]. Thompson’s argument that inspecting a checker’s source tells you nothing if the tool that produced it is compromised is the origin point for verifying the verifier [55]; what follows is the mundane, non-adversarial version of the same regress.

Two entries in this literature bear directly on my Section 5.2 rule, and both cut against its novelty while supporting the paper’s thesis. in-toto’s layout model already carries the closure obligation [56], and the specification states it explicitly: there is an implicit “ALLOW *” at the end of each rule list, and “[n]ot including “DISALLOW *” at the end of a rule list could allow artifacts to sneak into the step or inspection undetected”, so it “is generally recommended that all rule lists include a “DISALLOW *” at the end” [22]. A mature framework identified the same fail-open shape, wrote the warning down, and still left the safe behaviour off by default. My rule is therefore

a re-derivation made mandatory, not a discovery. In the same direction, the in-toto attestation Statement layer imposes no requirement that a verifier evaluate every subject [23], and the SLSA v1.2 build track states that “SLSA v1.0 does not have any requirements on the completeness or verification of `resolvedDependencies`” while separately advising that “[v]erification tools SHOULD reject unrecognized fields in `externalParameters` to err on the side of caution” [54]. That second rule is the fail-closed-on-unknown convention my Section 5.3 defect violates, one scope over.

4.7 Evaluation harnesses and leaderboards

The bundles this verifier accepts are, in practice, evaluation results. Biderman et al. name sensitivity to evaluation setup and lack of reproducibility as structural problems of language-model evaluation, written from years of operating a harness [6]. Zhao et al. study 1,045 foundation-model leaderboards and catalogue recurring workflow smells [62]. Together these are the demand-side argument for an offline recomputable evidence bundle, and the reason the host-dependence result in Section 7.7 belongs to a studied class rather than to personal carelessness.

4.8 What is left unclaimed

After all of that, the honest residue is narrower than the earlier draft implied. Statement deletion is Untch’s. Extreme mutation is Niedermayr’s, and its statement-granularity form is Maton’s. Deleting the statement that signals rejection is Kumar’s. Mutating a checker to grade it is muSE’s, MASC’s and Chen and Furia’s, and as of August 2026 it is also Delcourt et al.’s in the semantic-judge setting [12]. Reporting that a large continuously green suite keeps shipping defects because of what its checks observe is Bilal and Mughal’s [7]. The green-baseline precondition in Section 6.4 is long-standing default behaviour in PIT, a widely used Java mutation engine, which validates baseline suite state before running [48]; my version of that rule is a rediscovery of standard tooling practice, and saying so costs nothing.

What remains unclaimed by prior work, as far as I can establish, is the combination of two things. The *site selection*: refusal statements enumerated as a population, each the sole point of rejection for one class of bad input, so that the denominator of the score is the checker’s own refusals rather than an arbitrary set of program points. And the *subject*: not the artifact the checker reads, which is what MASC and Delcourt et al. mutate, but the checker’s own acceptance logic, whose verdict is published. Each of the two is a specialisation of something already published, and the combination is narrow.

The two-detector kill predicate is not a third novelty, and an earlier draft of this section implied that it was. Deciding a kill by exact, machine-checkable suite state is the ordinary arrangement in conventional mutation testing; it looks distinctive here only against two comparators that could not have had it, one grading language models by embedding similarity and the other triaging its unkillable mutants by hand. What the predicate buys is not novelty but decomposition. Because the corpus disjunct can be scored with the unit-suite disjunct removed, the corpus written to prove the verifier can refuse can be asked what it catches on its own, which is 10 of 112 (Section 7.1), the paper’s least comfortable number. MASC reports the same shape of result from the other side of the pipeline, attributing 45 of 76 crypto-detector flaws to mutation and only 31 of 76 to literal base instantiations of the same misuse cases [2]. The partition differs: theirs is between two stimulus sets against one detector, mine between two detectors over one mutant population, so my number scores a standing regression asset rather than a baseline for the mutants. The direction of the finding is the same in both, and it was theirs first.

Read strictly, then, this is a case study carrying a specialised instrument rather than a new method, and the contributions in Section 1 are worded to say so.

5 Four forgeries against the hardened verifier

All four run against `main` at `f59fb62`, after the soundness fix of Section 2.2. Every run is preceded by a liveness control: `python -m vac.verify fixtures/valid` must exit 0. Without that control a sweep proves nothing, and Section 9 records exactly that going wrong twice.

5.1 The lie typed as a string

`results.summary` values are compared against recomputed quantities by a walk that returns early on any leaf that is not `int` or `float`. Retype every summary number as a JSON string and nothing is ever compared. No artifact is touched. No hash is re-pinned.

```
summary: {"verdicts": 3, "fixed": 2, ...}
-> {"verdicts": "9999", "fixed": "9999", ...}
exit=0    structural verification: PASS
```

The specification blessed this. `SPEC.md:139` at `f59fb62`, inside section 2.5 `results`, reads in full: “Non-numeric, descriptive values pass through.” This is therefore a specification hole, not an implementation slip. The spec permitted a class of lie it had not imagined. It is also, in taxonomy terms, a failure to validate consistency between elements of one complex input [38]: the headline field and the artifact it summarises must agree, and retyping the field removes the comparison rather than failing it.

5.2 Deleting the check instead of breaking it

`_validate_manifest` requires only that `results.checks` be a non-empty list. Nothing requires a listed evidence artifact to be covered by any check. Delete the check that recomputes a number and the number moves from the strictly-bound branch to a loose branch that accepts any value appearing anywhere in the recomputed pool.

```
checks: [certlab-bundle-v1, fleet-board-v1, evalmut-run-v1,
         crashkit-battery-v1, modeldrift-board-v1]
-> [fleet-board-v1, evalmut-run-v1, crashkit-battery-v1,
    modeldrift-board-v1]
exit=0    structural verification: PASS
```

The audit’s fix made *breaking* a check a named refusal. It left *deleting* one free. This is the general lesson of hardening: constraining how a check fails does not constrain whether it runs. As Section 4 notes, in-toto’s specification already recommends the catch-all rule that closes this, as an opt-in [22]; the claim here is about my own specification, not about attestation frameworks in general.

5.3 One capital letter

The crashkit profile weights findings by severity. At `f59fb62`:

```

_CRASHKIT_WEIGHTS = {"none": 0, "low": 1, "med": 2, "high": 4,
                     "critical": 8} # verify.py:548
total_w = sum(_CRASHKIT_WEIGHTS.get(c.get("severity"), 0) ...) # verify.py:594
failed_w = sum(_CRASHKIT_WEIGHTS.get(c.get("severity"), 0) ...) # verify.py:596

```

`.get(sev, 0)` maps any unrecognised label to zero. Re-case the severity on the *failed* cases only and their weight vanishes from the numerator while the passing cases keep theirs. The score divides to 0.0 through the ordinary arithmetic path. It never touches a guard, an exception, or a fallback branch.

```

case severities    [critical, critical, high, med, med]
graded subset     [critical, critical, high, med]    (one med case is
                                                    truncated, so it is
                                                    excluded from grading)

honest weights total 8+8+4+2 = 22, failed 8+2 = 10
vulnerability_score = 10/22 = 0.4545

tampered          [critical, Critical, high, Med, Med] (3 re-cased,
                                                    failed rows only)

graded weights total 8+0+4+0 = 12, failed 0
vulnerability_score declared 0.0
evidence/eval_run.json sha256 re-pinned HONESTLY
exit=0 structural verification: PASS

```

The truncated-case exclusion is spelled out because without it the arithmetic is not reproducible from the printed severity list, and a paper about offline recheckability cannot afford an example a reader cannot recompute.

At `f59fb62`, `grep -rn severity tests/` returned zero matches across all three test files. And `SPEC.md:306-307` at the same commit stated the rule plainly, that the severity weights are “the same weights crashkit grades with; an unknown severity weighs 0”, so, as in Section 5.1, the specification wrote the hole down and called it a decision. That is the CWE-636 pattern precisely: a design that falls back to a more permissive state [40]. At `92e4548` the same `grep` returns 13 matches, because the fix brought tests with it.

A security score of 0.0 on a bundle whose own rows record three failed cases is then copied verbatim into the public registry.

5.4 Deleting the stamp rather than faking it

Four stamp comparisons are guarded on the artifact-side key existing (`verify.py:284, 288, 374, 383` at `f59fb62`). An issuer who deletes those keys and re-pins honestly passes all four without a single comparison executing, while the report still claims *stamp agreement*.

This one carries the cleanest discriminator in the paper, because the same fields corrupted rather than removed are refused by name:

```

WRONG VALUES (harness_commit/taskset_hash/prompt_hash = "DEADBEEF")
  exit=1  FAIL stamp-mismatch: taskset_hash: protocol 00112233445566aa,
                                                artifact DEADBEEF
        FAIL stamp-mismatch: prompt_hash:  protocol aabbccdd00112233,
                                                artifact DEADBEEF

```

<pre> FAIL stamp-mismatch: harness_commit: protocol f1e2d3c, artifact DEADBEEF KEYS DELETED (same fields, removed; sha256 re-pinned honestly) exit=0 structural verification: PASS protocol.hashes still declares all 7 pins </pre>
--

The check is demonstrably alive and fires on corruption. It is blind to absence. Another profile fails closed on exactly this case one branch along: `verify.py:642` at `f59fb62` compares the pinned hash against the artifact's `git_sha` directly, so a deleted key compares unequal and is refused by name rather than skipped. The behaviour is therefore an asymmetry rather than a design decision. Two nearby comparisons that look like counterexamples are not: `verify.py:639` guards the `protocol` operand, firing when the key is absent from `protocol.hashes`, which is the reverse of this forgery, and the modeldrift stamp check at `verify.py:1000` compares against a recomputed fingerprint, so its artifact operand cannot be deleted at all. It is CWE-754 in its adversarial reading: the programmer assumed a condition would not occur, and the party who decides whether it occurs is the issuer [42].

The general form is worth stating: **a comparison guarded on both operands existing is not a check, it is a suggestion.** The party supplying one operand decides whether the comparison happens.

6 Method: refusal-site deletion

The four findings above were found by hand, which makes them anecdotes. To turn them into a measurement I applied a mutation operator to the verifier itself, implemented as `tools/mutation_sweep.py` in the repository.

6.1 The operator

Definition 2 (Refusal site) *A refusal site is one source statement that appends a named failure reason to the failure list returned by `verify_bundle`. Operationally the sweep selects lines matching the regular expression*

`^\\s*(f|failures)\\.append\\(`

in `vac/verify.py`. In that file the live idiom is `f.append()`; the alternation exists because `vac/registry.py` uses the longer name. An earlier draft of this paper described the sites as `failures.append` statements, which was simply wrong for the file being measured; the wrong name had been copied from the sweep's own docstring.

Definition 3 (Operator) *The refusal-site deletion operator replaces one refusal site with `pass`, generating one mutant per site. This is statement deletion [14, 57] restricted to a chosen statement class, in the same family as throw-statement deletion [29] and catch-block deletion [26].*

At `f59fb62` the file contains 112 refusal sites. At `92e4548` it contains 146, of which 3 are excluded (Section 6.3), leaving a denominator of 143. Both counts are reproducible with the grep above.

6.2 The kill predicate

Definition 4 (Caught) *A mutant is caught if any of the following holds: (i) the unit suite fails; (ii) the liveness control breaks, that is `python -m vac.verify fixtures/valid` stops exiting 0; or (iii) any committed tamper fixture stops being refused, that is stops exiting 1. Otherwise it survives.*

The three-way disjunction is deliberate, and so is the order. The sweep evaluates the disjuncts in the order written and reports the first that fires, which makes the score cheap but makes the per-disjunct attribution *marginal* rather than absolute: the fixture disjunct is only ever reached on mutants the unit suite has already missed. That asymmetry matters enough that Section 7.1 scores the fixture corpus a second time as a detector standing on its own, and the two numbers are not the same.

Definition 5 (Score)
$$\text{score} = \frac{\text{mutants caught}}{\text{refusal sites} - \text{exclusions}}.$$

This is an adequacy measurement in the sense of Budd et al. [10] and Zhu et al. [63]: it measures whether a suite detects a chosen class of artificial change, never whether the verifier is correct.

6.3 Exclusions

Some refusals cannot be reached by any bundle-shaped input. Counting them as caught would inflate the score; leaving them in as permanent survivors would make the denominator lie. The sweep therefore carries an explicit exclusion set, keyed by a distinctive source fragment together with the number of lines that fragment is *expected* to match, so that a rename or a refactor aborts the run rather than silently resizing the denominator in either direction. This mirrors the arid-line practice reported at Google [47].

At 92e4548 the exclusion set holds two fragments covering three source lines, and both are `OSError` wrappers:

- one line wrapping the read of `RESULTS.md`: to reach the check the artifact must already be in the trusted set, which required an `is_file()` plus a full sha256 read of the same bytes, so only a filesystem race between the hash pass and this read could fire it;
- two lines wrapping reads in both render comparators, for the same reason: a render not listed in evidence is refused earlier as `check-artifact-not-listed`, and one that is listed was already opened and hashed before the check runs.

Both were probed empirically rather than assumed. An earlier draft described the two exclusions differently, as one unreachable `flips.json` branch and one `OSError` wrapper; that description matched an intermediate state of the code and no longer matches the exclusion set, which is why the composition is restated here rather than referenced.

6.4 The validity gate

The sweep aborts unless the unmutated baseline is green. This is a precondition of the measurement, not a convenience, and Section 7.4 is the incident that bought it. It is also standard: PIT validates baseline suite state before running mutation analysis [48] and refuses outright when it is red. That refusal is not on the cited FAQ page, which lists only causes of a green-locally, red-under-PIT discrepancy; it is in the source, where `DefaultCoverageGenerator` throws `PitHelpError(Help.FAILING_TESTS)`, whose message reads “Mutation testing requires a green suite”, with `skipFailingTests` defaulting to `false`.

The gate covers two things and not a third, and the gap is worth naming because it is the same shape as everything else here. It covers baseline greenness, and it covers exclusion arity: each excluded fragment declares how many lines it should match, and a mismatch aborts. It does not cover the *site population*, which is the denominator. Nothing asserts how many refusal sites the enumeration should find, so a behaviour-preserving refactor can resize the denominator silently. Demonstrated on a clean copy of 92e4548: moving four `stamp-mismatch` refusals into a one-line `_refuse(f, msg)` helper leaves the suite byte-identical (237 passed, 16 skipped, 4 xfailed, plus one pre-existing failure on the interpreter used, both before and after), keeps both exclusion counts matching so nothing aborts, and moves the enumeration from 146 raw sites to 143, a denominator of 140 rather than 143. Four distinct refusal obligations now share one site whose deletion breaks all four, so that site is trivially killed: real coverage falls while the score rises. CI’s `--floor 0.99` is a floor on the ratio and would not notice. Pinning an expected site count the way `EXCLUDE` pins its arity is the obvious fix. This paragraph describes 92e4548, where it was not done; the pin landed afterwards at e932868, and run against that revision the same refactor aborts the sweep with exit 2, reporting 143 raw sites and 140 scored where 146 and 143 are declared, instead of scoring the smaller denominator (Section 13.2).

7 Results

7.1 RQ1: baseline refusal-site liveness

At f59fb62, with a 114-test suite (measured by `pytest --collect-only`) and 16 committed tamper fixtures:

112 mutants, one disabled refusal each	
37 caught	all 37 by the unit tests
75 SURVIVED	undetected by the test suite AND the tamper sweep
MUTATION SCORE	37/112 = 0.330
survivors by refusal class	
26 raw-aggregate-mismatch	6 summary-mismatch
20 artifact-unparsable	4 stamp-mismatch
16 schema-violation	1 check-artifact-not-listed
	1 duplicate-artifact
	1 issuer-commit-mismatch

Two thirds of this verifier’s refusals could be silently deleted with every gate still green.

The second number is worse than the first, and it needs stating more carefully than an earlier draft of this paper managed. The 16 tamper fixtures exist as a CI job named `invalidation-liveness`, whose stated purpose in the workflow file is that “[t]he verifier must prove it can both pass and BLOCK ... A gate that never fires certifies nothing.” Of the 75 mutants the unit tests missed, that job caught **zero**.

That zero is real but it is not a surprise, and presenting it as one would be this paper committing its own subject. It is entailed. At f59fb62 every one of the 16 fixtures is named in `tests/test_verify.py`’s `TAMPERS` map, which asserts both `verify_bundle(FIX / name) == expected` and `main([...]) == 1` for each. So a mutant that stops a fixture being refused fails a unit test first, the sweep returns `tests`, and the fixture disjunct is never evaluated. Given a suite that pins every

fixture’s exact verdict, the corpus’s *marginal* contribution over that suite is zero by construction, not by misfortune.

The number that is not entailed is the corpus scored on its own. Re-running the same 112 mutants with the unit-suite disjunct removed, so that only the liveness control and the fixture corpus can fire, gives **10 caught of 112, a score of 0.089** (measured 2026-08-18 on a clean copy of **f59fb62**). Ten of the sixteen fixtures each flip exactly one mutant from refused to accepted; the other six flip none.

That 0.089 sits against a ceiling the corpus cannot exceed, and the ceiling is structural rather than a matter of how well the fixtures are written. Each fixture is a single boolean detector: it either exits 1 or it does not. If its bundle’s failures all trace to one refusal site, deleting that site flips it and deleting any other site does not; if they trace to more than one, no single deletion flips it at all. So each fixture can be flipped by at most one mutant in the whole population, and n fixtures cannot score above $n/112$: here $16/112 = 0.143$. Adding fixtures buys coverage linearly while refusal sites accumulate with the code. A gate built to prove a verifier can refuse, sized at one fixture per imagined attack, cannot keep up with a refusal population seven times its size. That is an argument about the shape of hand-written corpora, not about this one’s quality.

An honest caveat, and it is the one a reviewer should press hardest: disabling a refusal is meaningful only if some input would have reached it, so some fraction of the 75 could be unreachable or genuinely redundant rather than untested. Reachability is not established per-survivor at this baseline.

What bounds that concern is not an analogy but this paper’s own endpoint. By **92e4548** a killing bundle had been constructed for every non-excluded site: the sweep scores 143/143, and a mutant dies only if some input reaches the deleted statement and some assertion notices. Over the whole exercise exactly two sites turned out to be dead code and three are excluded as unreachable (Sections 6.3 and 7.5), so the unreachable population is five enumerated lines rather than an unknown fraction. The limit of that argument, stated so it is not overread: the 143 sites at **92e4548** are not the same set as the 112 at **f59fb62**, so this bounds the concern rather than proving reachability survivor by survivor at the baseline. Four independently confirmed forgeries separately establish that at least some baseline survivors were live.

For external calibration in the other direction, static C analyzers miss 47% to 80% of real vulnerabilities in benchmark programs [34], and Beer et al. report that roughly a fifth of passing formulas in industrial hardware verification were vacuous [5]; a two-thirds gap looks like personal negligence in isolation and like an industry baseline beside those.

7.2 RQ4: does the operator anticipate the manual findings?

This is the method’s strongest validation, and it needs one correction the earlier draft did not make.

Table 1: Each hand-found forgery against the surviving refusal population.

Section	Forgery	Related survivor class	Anticipated?
5.1	string-typed summary lie	summary-mismatch (6)	yes
5.2	deleting the check	check-artifact-not-listed (1)	no, see below
5.3	capital-letter severity	raw-aggregate-mismatch (26)	yes
5.4	deleting the stamp	stamp-mismatch (4)	yes

Three of the four hand-found forgeries make a *live* refusal unreachable, and in each case that refusal is a survivor: Section 5.1 makes a **summary-mismatch** unreachable, Section 5.3 makes a **raw-**

`aggregate-mismatch` never fire, and Section 5.4 makes a `stamp-mismatch` skip its comparison. For those three the measurement does not merely agree with the manual audit, it points at it.

The fourth is different and the earlier draft’s table overstated it. The defect in Section 5.2 is an *absent* obligation: no refusal site existed for an evidence artifact covered by no check, and the fix had to create one. An operator that deletes existing refusal statements cannot, by construction, see a refusal that was never written. The surviving `check-artifact-not-listed` refusal is adjacent (it names the inverse relation, a check referring to an artifact not listed) but it is not the same obligation. Counting it as a prediction would be the paper indicting itself.

So the claim is: the operator anticipated three of four, and was blind to the fourth in a way that is a property of the operator family rather than of this run. That is a weaker claim than the draft made and it is still the strongest validation in the paper, because the four forgeries were found independently and by hand.

The manual search took an external audit to teach me the shape, then a day of adversarial work. The mutation run is unsupervised and cheap: at 92e4548 the 143-mutant sweep completed in 5 minutes 46 seconds on an Apple M4 (measured once, 2026-08-18, on a clean copy of that commit). The duration of the original 112-mutant run was not archived, and an earlier draft’s “eleven minutes” is not reproducible; it is dropped rather than restated. What the run added beyond the four categories was 72 further places to look: of the 75 survivors, three are the refusals that three of the four hand-found forgeries make unreachable, and the fourth subtracts nothing, because no refusal site existed for it.

7.3 RQ2: what bug-specific hardening bought

I fixed all four defects in Section 5 and added a tamper fixture per fix, so the `invalidation-liveness` job could prove each new refusal fires. Every forgery is now refused by name, and all 20 fixtures are refused against a passing live control (verified at 92e4548: `fixtures/valid` exits 0 and all 20 `fixtures/tamper-*` exit 1). Re-measuring at 6b6f96f:

BEFORE	37/112 = 0.330	(f59fb62, 114 tests, 16 fixtures)
AFTER	39/119 = 0.328	(6b6f96f, 114 tests, 20 fixtures)

The score did not move. Two of the four new fixtures kill a mutant; the other two kill none. Closing four holes required seven new refusal statements, themselves untested. The `stamp-mismatch` survivors went from 4 to 8. Four bugs fixed, seven guards added, net coverage flat.

An earlier draft hedged that “much of” the decline was denominator growth. The archived sweeps decompose exactly, and the exact statement is stronger than the hedge. The unit suite caught 37 mutants before and 37 after; the two additional catches after are both by new fixtures (`tamper-summary-string` and `tamper-check-deleted`). Caught counts per refusal class are identical in every class except the two that gained a catch, and in both of those the catch falls on a newly added site. So **the effect of the four fixes on the 112 pre-existing sites is exactly zero**: that population scores 37/112 both before and after. The whole of the movement is the seven new sites, which were themselves covered at 2/7, a rate no better than the code being fixed.

The precise claim is therefore narrower than the headline number invites, and sharper: *the bug-specific regressions closed the four demonstrated vulnerabilities, left the liveness of every pre-existing refusal untouched, and installed seven new refusals that were themselves mostly untested*. They sampled the failures that had been discovered rather than exercising the remaining population of refusals. Reported as a decimal delta the change is -0.003 ($0.330357 \rightarrow 0.327731$); the rounded

scores in the box above differ by -0.002 , and the fractions are quoted throughout in preference to either.

It would be wrong to say the fixes bought nothing. They closed four working forgeries and pinned each against return. What they did not do, and what a careful engineer would expect them to do, is make the *rest* of the gates any more likely to fail when they should. The mass was 26 surviving `raw-aggregate-mismatch` refusals concentrated in one profile’s checker, which no audit had a reason to look at.

7.4 The measurement lied first, and scored a perfect 1.000

The first post-hardening run reported $119/119 = 1.000$.

It was false. The harness ran `pytest -x`, and the baseline was *already red*: the two tests that assert the real evalmut and crashkit bundles verify clean had just been (correctly) broken by the new evidence-unchecked rule. Pytest therefore exited nonzero for every mutant, every mutant scored “caught”, and the score reported a perfect suite while measuring nothing at all.

A tool built to detect checks that pass without checking produced a check that passed without checking, and the failure presented as the best possible result. Had I reported 1.000 it would have been the most flattering and most worthless number in this project. The published literature has the same warning from the other side: assertion-free suites still achieve substantial mutation scores by relying on uncontrolled implicit checks [50].

The fix is the rule this paper already argues for, applied to itself, and it is the validity gate of Section 6.4. A liveness gate on the liveness instrument.

7.5 RQ3: what did move it, testing the refusals rather than the bugs

The survivors were never a mystery. They were a work list. Seventy-five tests were written, one per refusal surviving at the 112-site baseline, organised by cluster rather than by defect. See Section 7.7 for a provenance caveat on how those tests were produced, which matters more than the count.

The discipline that made them worth anything is the same one the rest of this paper is about. Each test asserts the *exact* failure list, never a substring search, so it cannot pass on a cascade it did not cause. And for most of them, disabling the target refusal makes `verify_bundle` return `[]` and the cooked bundle verifies clean, which proves that refusal is the *sole* guard for its defect rather than one voice in a chorus. Several tests were rewritten mid-flight when that check revealed they were leaning on a stale-hash backstop instead of the arithmetic they claimed to pin. This is oracle improvement in the sense of Jahangirova et al. [25], and the mechanism by which it works is the one Zhang and Mesbah [61] measured: what moves detection is assertions on behaviour, not more executed code.

Table 2 gives the full ladder with the code state each row was measured on, because the two headline deltas are otherwise not comparable: the 0.941 run sits on the post-fix tree, so it already contains the seven refusal sites the fixes added.

The full record, including the parts the table smooths. Table 2 shows five rows: one fall and then three clean rises. The repository holds twelve archived sweeps, two of which record the same 39/119, so eleven values, and they fall three more times. In commit order the measured scores are 0.330, 0.328, 0.941, 0.957, 0.960, 0.953, 0.947, 0.992, 1.000, 0.972 and 1.000. The score fell four times: $0.330 \rightarrow 0.328$ when the four bug fixes added seven sites, $0.960 \rightarrow 0.953 \rightarrow 0.947$, and $1.000 \rightarrow 0.972$ when a new profile added twelve refusal sites. In every one of those falls the numerator rose or held (the sequence of caught counts, 37, 39, 112, 112, 120, 123, 126, 130, 131,

Table 2: Refusal-site liveness coverage by code state. Sites and test counts measured directly at each commit; scores read from the archived sweep outputs in `paper/`. The 0.330 and 0.328 rows use no exclusions. The fourth row’s commit was not recorded alongside its archived sweep at the time and is recovered from the repository: eight commits carry 134 refusal sites, but only three of them carry a one-line exclusion set and so can produce the denominator 133, and of those `a17af5c` is ruled out because it scored 123/133 (Section 7.7). The remaining two differ only in paper files, and `1674f4c` is the commit that introduced `paper/mutation_final2.json`, 42 seconds after that file’s own mtime. The row is pinned there.

Stage	Commit	Sites (excl.)	Caught	Score	Tests
baseline	<code>f59fb62</code>	112 (0)	37	0.330	114
after the four bug fixes + fixtures	<code>6b6f96f</code>	119 (0)	39	0.328	114
after per-refusal liveness tests	<code>6c3a2c8</code>	119 (0)	112	0.941	189
after closing every issuer’s gap	<code>1674f4c</code>	134 (1)	126	0.947	217
after covering the remainder	<code>92e4548</code>	146 (3)	143	1.000	258

139, 143, never decreases); what moved was the denominator. Nothing ever stopped being caught. New gates arrived untested.

That is the RQ2 phenomenon recurring *after* the RQ3 intervention, and it is the strongest argument in this paper for making the sweep a standing CI floor rather than a one-time measurement: a codebase that adds refusals adds them uncovered by default, and the score decays unless something asks. Reporting only the table’s five rows would have made a sawtooth look like a ramp, which is a presentation choice this paper in particular cannot afford.

Two further clarifications the table forces, and both were errors in the earlier draft. First, the 75 tests were one per survivor at the *112-site* baseline; by the time they were measured the tree had 119 sites and 80 survivors, so “one per surviving refusal” describes the work list, not the tree the score was taken on. Second, the $0.330 \rightarrow 0.941$ and $0.330 \rightarrow 0.328$ deltas are both quoted against the same baseline for comparability, but the second measurement is taken on top of the first, not as an alternative to it.

At the 0.947 row, seven refusals still survived, and the honest breakdown mattered: two were dead code, not untested. One was unreachable because a non-dict `flips.json` is already refused upstream by the JSON loader’s `want=dict`; the other was an `OSError` wrapper no bundle-shaped input can reach, since the artifact must already have been read and hashed to enter the check. Both were probed empirically rather than assumed, and no test was written to fake coverage of them. The dead one was deleted; the unreachable one moved into the exclusion set described in Section 6.3, which has since grown to three lines across two fragments as more render comparators were added.

The 1.000 at `92e4548` is not the vacuous 1.000 of Section 7.4: the sweep’s own liveness gate passed first, printing `baseline clean; 143 refusal sites (3 excluded, see EXCLUDE)`. I reproduced it independently on a clean copy of that commit, and it matches the project’s own continuous-integration log for the same commit. CI enforces `--floor 0.99`.

How much of the +0.611 is entailed. Most of it, and saying so is the price of the rest of the paper. The RQ3 intervention is defined in the metric’s own units: one test per surviving site, each asserting the exact failure list that site produces. A test shaped that way fails when its site is deleted, by construction. So once the tests land, the score moves; the movement measures completion of a work list, not an independent gain in oracle quality. The RQ2 arm, by contrast,

was defined over *defects* and never targeted a site, which is what any defect-shaped intervention scores on a site-liveness metric. The gap between -0.002 and $+0.611$ therefore measures targeting at least as much as efficacy, and no design in this paper separates the two.

Two things in that run are not entailed, and they are the section’s real content. The first is reachability: it was not known in advance that a bundle-shaped input existed for each site, and two sites turned out to have none (Section 7.5). The second is that the resulting metric has teeth on code written afterwards, which is a claim about the future rather than about the work list, and Section 7.7 is where it was tested: the CI floor caught a comparator I had added and not tested, at a commit where no test had been written for it. Earning the efficacy claim properly needs the pre-registered second operator family (Section 13.2), scored against tests that were not written with that operator in view. That is not done.

With those qualifications, the comparison between the two middle rows is still the paper’s practical claim. Fixing named defects and pinning each with a regression fixture, which is the instinctive post-audit response, left the pre-existing population at 37/112. Systematically asking “can this gate fail?” of every gate took it to 112/119. **The defects you find are a sample; the gates you own are the population.** Offered as a heuristic drawn from one system, not as a demonstrated law, and partly true by construction.

7.6 The closure rule found the same gap in three issuers

The rule from Section 5.2, that an artifact listed as evidence must be read by some check, was written to close one forgery. Turned on the live registry, it refused three of the five issuer families.

Table 3: Artifacts pinned as evidence but read by no check, when the closure rule was first run against the live registry.

Issuer	Pinned but unchecked
crashkit	<code>variance_flaky_n10.report.json</code>
evalmut	<code>dogfood_gradecore.txt</code> , <code>promptfoo_findings.txt</code>
agent-certlab	<code>CONTRACT.md</code> , in all seven certifications

Three of the four artifacts are the human-readable view: two `.txt` renders and a `.md` contract. The fourth does not fit that description and is recorded rather than smoothed over: crashkit’s `variance_flaky_n10.report.json` is machine-readable JSON and was unbound anyway. So the class the rule actually caught is broader than “human-readable”: it is *artifacts produced as reports rather than consumed as a check’s input*. Under that description all four fit, and the human-readable ones are the subset where it costs most, because that is the document a person actually reads. Crashkit’s capability sentence claimed its variance report “aggregates reproducibly”; certlab’s contracts announced “N/M seeded defects fixed”. True claims, unverified.

The fix in each case was to bind the render to its payload. Not byte-identity re-rendering, which would couple the verifier to another repository’s formatting, but holding the render’s headline to the recomputed values, with an unparseable render refused rather than skipped.

I do not claim the other two issuer families were clean. The rule fired on three; whether fleet-board and modeldrift had no closure gap, or simply were not reached by this sweep, is not established here.

Stated as a hypothesis, because the sample cannot support more. These are repos by one author, in one suite, under one set of conventions: a within-author architectural pattern, not

evidence about attacker behaviour or about the industry. What it suggests, and what is testable, is that *an artifact emitted as a report is systematically underbound relative to an artifact consumed as a check's input*. The mechanism is mundane enough to be plausible elsewhere: authors bind what a check reads and treat what a reader reads as disposable, right up until the second is the thing people act on. The crashkit row is the case that constrains the wording, since it is a report in JSON: what predicts the gap is the artifact's role, not its file format, and a narrower “renders go unbound” hypothesis is already refuted at $n = 4$. Zhao et al.'s population-scale catalogue of leaderboard smells is the nearest independent evidence that the pattern is not unique to me [62], though I have not checked their smell definitions against this mechanism and do not claim the mapping.

Testing it properly means going outside this codebase: sample public attestations, CI-generated security reports, evaluation write-ups and model cards; ask whether the displayed summary is deterministically derived from signed or bound data; separate generated reports from hand-authored narrative; and fix the coding rule before looking at outcomes. Fourné et al.'s interview study is the methodological template for doing that properly [17]. That study is not in this paper.

Present state, stated honestly. At the 2026-08-16 measurement all three issuers were re-emitted, landed clean, and the registry re-pinned byte-identically. That is no longer true. Measured on 2026-08-18 at 92e4548: crashkit verifies with 0 failures; evalmut fails with 1, an **evidence-unchecked** on `dogfood_fixtures.json` and `promptfoo_fixtures.json`; model-drift fails with 14, thirteen **raw-aggregate-mismatch** rows in `standings.json` plus a render mismatch. The verifier has not changed since ba14203 (2026-08-16); the issuer bundles drifted. Notably, evalmut's re-emission reintroduced exactly the gap this rule exists to catch, which is a live datapoint in the rule's favour and an uncomfortable one for the project's release hygiene.

7.7 Host dependence of the measurement

The CI floor failed on its first real push. At a17af5c, the **refusal-coverage** job printed **baseline clean**; 133 refusal sites (1 excluded), then **MUTATION SCORE: 123/133 = 0.925** and **FAIL: 0.925 is below the floor 0.940**. Part of that was my own omission: I had added a comparator and not tested it, which is exactly the rot the floor exists to catch, and it caught me.

An earlier draft compared that 0.925 against “0.953 locally” and attributed the gap to host dependence. That comparison was wrong and I am reporting the correction rather than quietly dropping it. The 0.953 is 123/129, measured at bfc9642, a tree with 130 refusal sites. The CI figure is 123/133 at a17af5c, a tree with 134. The intervening commit added exactly the four refusal sites that account for the entire difference, and the numerator is identical at 123. Nothing stopped being caught. The gap was commit skew.

The underlying host-dependence claim is nevertheless true, and I re-established it by a different route. Fourteen tests are gated on sibling issuer checkouts being present. Without them the suite runs 238 passed, 16 skipped, 4 xfailed; with the checkouts correctly wired the same suite runs 14 more tests. So the suite a developer runs and the suite CI runs are not the same suite, which is the same class as a verdict that changes with the filesystem encoding, the defect the external audit opened with. What I can no longer support is the specific claim that four mutants stop being caught. At 92e4548 the sweep scores 143/143 on a checkout *without* the sibling repositories, which is the only configuration in which it currently runs at all: with them present, two drifted issuer bundles make the baseline red and the sweep aborts by design (Section 6.4). So that claim is not re-measurable today, and it is withdrawn rather than restated.

An earlier draft also stated that CI now checks out the issuers “so it measures what a developer measures”. It does not. That is instrument failure seven in Section 9.

Provenance of the 75 tests. The 75 tests were not written serially by one author, and the 0.941 above is a single serialised sweep rather than an aggregate of their self-reports. The reason that distinction matters is a threat to validity and is stated under Test provenance in Section 12.

8 Why the existing suite missed all of this

Every fixture encodes a forgery I had already imagined. `tamper-wrong-sha256` tests a hash that does not match its artifact; the audit’s attack re-pinned the hash *honestly*. The fixture set is a map of my own threat model, and a threat model cannot contain its own blind spot by construction. The obvious external correction is to derive fixtures from a published attack taxonomy [32] or to generate them adversarially rather than by hand, as frankencerts do for certificate validation [9].

The 114 tests were not idle either. They executed the verifier extensively. What they did not do is assert that its refusals could fire, which is the distinction checked coverage was invented to measure [50] and the reason coverage is a poor quality target [24]. A covered line is not an asserted line, and 75 surviving refusal sites is what that gap looks like when you count it.

The sharper point concerns a tool I had already built and never applied here. *evalmut* injects known defects into a system and reports which checks stayed green. VAC verifies evalmut bundles; it had never been mutated by evalmut. The verifier is a grader, and I never graded the grader. That is Thompson’s regress in its most mundane possible form [55], and it is where the auditor walked in.

9 Instrument failures observed during the study

This section exists because omitting it would make the paper an instance of its own subject.

1. A tamper sweep printed *all 16 refused* while every invocation had exited 127. A startup failure, not a refusal. The loop scored “nonzero exit” as “correctly refused”.
2. Re-running the sweep months later, all 16 exited 2. A wrong module path. Identical symptom, different cause. The live control caught it; without the control the run would have read as a clean sweep.
3. Inside the script I wrote to hunt this bug, a probe edit failed on a wrong filename and printed `exit=0`. That was the *unmodified* bundle passing. The tool built to find vacuous passes produced one.
4. A proof-of-concept for a fifth finding ran against a stale local `origin/main`. After `git fetch` the premise evaporated. The finding was void.
5. The first post-hardening mutation run scored a perfect 1.000 against an already-red baseline: `pytest -x` exited nonzero for every mutant, so all 119 scored “caught”. The tool built to find vacuous passes produced one, and it presented as the best possible result (Section 7.4).
6. Editing *this paper* to insert the mutation result, a `str.replace()` on the abstract matched nothing and returned the string unchanged. The build succeeded, the PDF regenerated, and the abstract still carried the old numbers. Python’s `str.replace` cannot fail; it can only

decline to do anything. The fix was to switch to an editor that errors on no-match, which is the entire thesis of this paper applied to a text edit.

7. The remediation written to remove host dependence reports success along a path where the thing it added is never read. The workflow sets `VAC_EVALMUT_CHECKOUT` and its two siblings to `_issuers/<repo>/vac`, but the three consumers (`tests/test_verify.py:286, :325` and `:349` at 92e4548) append `/vac` themselves, so the value resolves to `_issuers/<repo>/vac/vac`. That directory does not exist in any of the three issuer repositories, whose bundle manifest sits at `<repo>/vac/vac.json`. Each `skipif` therefore fires and the six tests gated on those three variables skip inside the very job that checked the repositories out. The other eight issuer-gated tests skip for an unrelated reason: `VAC_CERTLAB_CHECKOUT` and `VAC_FLEET_CHECKOUT` are never set by the workflow at all, so agent-certlab’s seven registry entries and reference-fleet’s one were never in reach. Two independent causes, one silent zero, and the totals hide the seam. Nothing in the log gives it away, which is the point: the `refusal-coverage` job emits no pytest tally at all, because the sweep captures pytest’s output and prints only its own lines. What does give it away is that the job’s score at 92e4548 is 143/143, identical to a sweep run with the variables unset. An earlier draft cited the 238 passed, 16 skipped, 4 xfailed line as the evidence; that line is emitted by the `test (3.11)` and `test (3.12)` jobs, which never check the issuers out and were never meant to, so it could not evidence anything about `refusal-coverage`. Citing the wrong job’s output for a claim about instrument blindness is a reporting error rather than an instrument failure: no tool returned success without measuring, I cited the wrong measurement. It is recorded here rather than silently repaired, and the underlying defect stands on the path arithmetic above, not on the line I misquoted.

Seven instrument failures in the system under study, all producing plausible output, plus one reporting error in this paper’s own account of the seventh. Four of the seven happened inside instruments written specifically to detect this class, across three distinct tools: the tamper sweep (items 1 and 2), the probe script (item 3), and the mutation sweep itself (item 5). Two of them (items 1 and 2) are CWE-390 exactly: an error condition detected and converted into a success signal [39]. The most dangerous was not the one that broke. It was the one that returned a perfect score.

Items 3 and 6 also share a root cause with two of the errors this paper corrects. The wrong refusal-site idiom and the wrong test count in the earlier draft both came from a working copy of a commit that had been reverted, which is the same failure as item 4: measuring a tree that was not the tree under test.

The operational rules that survive:

- **Prove the instrument before the finding.** A liveness control adjacent to every sweep.
- **Re-run the ruled-out list after any fix.** A stale exclusion is indistinguishable from a real one.
- **Prefer operations that fail loudly over operations that silently no-op.** `str.replace`, `dict.get(k, default)`, `if k in a and k in b`, and `grep | true` are the same hazard wearing different clothes: they convert “did not happen” into “fine”.

10 Discussion

Any eval suite, CI gate, or verifier can be audited with two questions.

1. **Can this check pass without executing?** Empty input, a missing file, a process that fails to start, a pattern that matches nothing, a swallowed exception, an unknown enum value absorbed by a default. This is the CWE-703 family [41], and its fail-open variant has a name and a number [40].
2. **Has the detector been proven able to fire, in this run, on this host?** Not “it has a test”. A liveness control adjacent to the assertion.

A gate that has never been observed failing has not been observed working. That is the whole argument for mutation-testing eval suites rather than trusting their green, and it is the argument the sanity-checking literature made first for model checkers [30].

The one caution worth adding is against a `grep`. At `f59fb62`, `grep -rn severity tests/` returned zero, which was true and useful. At `92e4548` it returns 13, because the fix brought tests. A pattern that matches nothing is evidence only if you have separately established that it *can* match, which is the same hazard the third operational rule above names.

11 Scope of claims

Six things, and nothing broader.

1. A reproducible case study of five fail-open and vacuous-pass classes in an offline evidence-bundle verifier, each with a working forgery: four found against the hardened verifier (Section 5) and one, the `null`-artifact forgery, reported by the external audit against the pre-hardening version (Section 2.2).
2. A refusal-site liveness instrument: the deletion operator, the enumerated refusal-site denominator, the deterministic two-detector kill predicate, the exclusion set, and the validity gate. The operator family, the practice of grading a checker by mutation, and the green-baseline precondition are all prior art (Sections 4.5 and 4.8); the site selection and the subject are what is offered, and the kill predicate is what makes the measurement decomposable rather than what makes it new.
3. An empirical before-and-after on *one* real verifier, comparing discovered-bug regression testing against systematic refusal-site liveness testing.
4. A separately scored detector result: the committed tamper corpus catches 10 of 112 refusal sites on its own, against a structural ceiling of 16/112 (Section 7.1).
5. A finding-shaped *hypothesis* that an evidence artifact emitted as a report is systematically underbound relative to one consumed as a check’s input (Section 7.6), untested outside this codebase.
6. A record of seven instrument failures during the study (Section 9).

It does not claim a general result about post-audit engineering practice, about verification systems broadly, or that this methodology transfers. It does not claim that pointing a mutation tool at a checker is new, that reading surviving mutants as blind spots in a checker is new, or that a continuously green suite shipping defects is a new observation. Section 4.5 names who reported each.

Every number here is self-measured on a system I wrote. The verifier, the tests, the mutation operator, the exclusion set, and this paper are all mine. The registry it verifies is a closed loop: all 11 entries are my own repositories across five of my own projects, which is one multi-repository fixture rather than five independent issuers. The single external data point in the entire record is the audit in Section 2.2. This is stated prominently rather than in a footnote because a paper about instruments that report success without checking has no business burying the fact that it graded itself.

12 Threats to validity

12.1 Construct validity

What the score is and is not. The operator disables refusal statements only. It does not mutate comparison operators, boundaries, or control flow. So the number is not an upper bound on anything: an upper bound constrains a broader unknown, and this constrains nothing outside its own population. It is a *complete score against a deliberately narrow operator over an enumerated set of refusal sites*, in the adequacy sense of Zhu et al. [63], and 1.000 means that obligation is discharged, not that the verifier is correct. Just et al. [28] bound the substitution from the other side: 17% of real faults are coupled to no mutant generated by common operators at all.

A live counterexample to what 1.000 means. The strongest evidence that the score does not measure correctness arrived while this paper was being written, from outside it. Pull request 8 reports a covered artifact replaced by a symlink pointing outside the bundle: the run exits 0 and prints `structural verification: PASS`, because the bytes hash identically, they simply live somewhere else on the verifying host. A verifier scoring 1.000 on this paper’s operator accepts that bundle. The two facts are compatible rather than contradictory, and their compatibility is the point: the operator asks whether each refusal that exists can fire, and a refusal nobody wrote has no site to delete. Section 13.2 carries it as open. The honest reading of 1.000 is that the enumerated obligation is discharged, and nothing more.

The denominator is a source-level proxy. A refusal site is one `f.append()` statement. That misses rejections expressed as raises, early returns, assertions, or exit-code propagation, and reasons built indirectly through helpers. The omission is countable rather than abstract: at 92e4548 six rejection points sit outside the mutated population and are never mutated, three early returns (`verify.py:1508` missing-manifest, `:1512` and `:1514` invalid-json) and three `raise ValueError` unsafe-tar-member rejections (`:1541`, `:1546`, `:1558`). The same six are outside it at f59fb62. More importantly the proxy misses fail-open behaviour that happens *before* any refusal is reached: parser defaults, canonicalisation, decoding, path resolution, duplicate-key handling, exception swallowing. And, per Section 6.4, the population is enumerated rather than pinned, so it can move under a refactor without the gate objecting. The honest name for what is measured is **refusal-append liveness coverage**, and it is the name that should be read wherever this paper says “mutation score”, including at 1.000.

The mutants themselves are sound. The obvious suspicion about a deletion operator is that the score is inflated by mutants that fail to compile or that kill the process rather than an assertion. Checked at 92e4548: all 146 mutants parse (`ast.parse`, 0 failures), no statement span swallows a neighbouring refusal site, and 115 of the 146 statements are multi-line, which the paren-balance

span handles. A random sample of eight mutants (seed 7) all died on assertion failures comparing `verify_bundle` output against an expected failure list, none on an unhandled exception. That sample was run on CPython 3.14 rather than the project’s 3.11 and 3.12, with one pre-existing byte-identity failure deselected, so it is a check on the operator rather than a figure from the paper’s own environment.

Closure is artifact-read coverage, not field-binding coverage. The rule in Section 5.2 proves a check *references* an artifact; nothing in it proves the check reads anything inside. A check could open a file and bind none of it. `tests/test_refs_are_bound_not_just_read.py` probes this mechanically by corrupting each referenced artifact and re-pinning honestly. Measured at 92e4548: 13 refs, of which 2 carry no corruptible value and are skipped, leaving 11 actually corrupted. Of those 11, four still verified clean. Two were the `schema` format-version field, one a non-load-bearing digit in a raw stream, and one an unrecomputed `models` count inside a narrative. These are unbound *fields* inside bound artifacts, not decorative refs, and they are recorded in a `KNOWN_UNBOUND` inventory. An earlier draft said “4 of 12”, which was wrong in both the denominator and the composition; the same error is in that test file’s own docstring, which is worth noting because the paper was quoting the code and the code was quoting nothing. The three-level ladder this exposes, artifact-read to field-binding to claim coverage, is roadmap, not result.

12.2 Internal validity

The author designed the operator and holds the result. I wrote the verifier, chose the mutation operator, defined the kill predicate, wrote the exclusion set, and wrote this paper. The operator could in principle have been selected after seeing which sites survived. The control I propose for this is pre-registration of a second operator family (Section 13.2) before running it, which is the practice the mutation-testing methodology literature recommends [46]. It is not yet done, so this threat is open.

Test provenance. The 75 liveness tests were produced by six concurrent workers sharing a single working tree, and at least one of them observed a sibling mutating `vac/verify.py` underneath its own verification sweep. Their self-reported “mutation-checked” counts are therefore not independently trustworthy: the tree each worker measured was not the tree it wrote against. The claim is the measurement, not the authorship. The 0.941 is a single serialised run of `tools/mutation_sweep.py` against a clean tree with the liveness gate satisfied.

The instruments failed seven times. Section 9 is, read strictly, an internal-validity section. Four of the seven failures occurred inside the measurement apparatus, and one produced a perfect score. Every number in this paper should be read as carrying that risk, mitigated but not eliminated by the liveness gate.

Reachability is not established per survivor. The 0.330 counts surviving refusal sites, not surviving *reachable* refusal sites. Two dead refusals were found and handled explicitly (Section 7.5); the rest were not individually probed at the baseline.

12.3 External validity

One verifier, one author, 11 registry entries across five repositories all owned by me. There is no second issuer, no second codebase, and no second annotator. The one external data point is the

audit. The closest thing to independent corroboration of the *class* is CVE-2022-35929 in cosign [52], which is a different system by different authors exhibiting the same shape.

12.4 Conclusion validity

There is no control condition, and the two arms differ in more than one way at once. The move from 37/112 to 112/119 is attributable to per-refusal liveness testing, but it is not separable from the effort expended: 75 tests is a large intervention, and a comparison against 75 tests spent some other way was not run. The null result for bug-specific hardening is on a much smaller intervention (four fixes, four fixtures), so the two arms are not effort-matched. They are also not matched in *targeting*, which is the larger problem and is stated in full in Section 7.5: the RQ3 intervention is defined over the metric’s own units and the RQ2 one is not, so part of the gap is definitional rather than empirical. Additionally, the score is host-dependent in the sense of Section 7.7: which tests run depends on which sibling repositories are on the machine.

13 Fixes

13.1 Landed

- **Unknown severity is a named refusal**, not weight 0. The lookup indexes strictly and a label outside the frozen table is **artifact-unparsable**, named by the offending label. **SPEC.md** changed with it and records the replaced rule explicitly.
- **An evidence artifact not covered by any check is a named refusal**, **evidence-unchecked**.
- **Non-numeric summary values are compared, not skipped**. A JSON string that parses as a number is now **summary-outruns-checks**. **SPEC.md** was amended rather than patched around, and it records why.
- **Stamp keys named in protocol.hashes but absent from the artifact are a stamp-mismatch**, matching the two profiles that already failed closed.
- **A tamper fixture per fix**. 20 fixtures, all refused against a passing live control.
- **The mutation sweep is a CI floor**. **tools/mutation_sweep.py --floor 0.99** runs in the **refusal-coverage** job.
- **The two unreachable refusals are resolved**. One was deleted; one moved into the documented exclusion set. This bullet appeared as a recommendation in the earlier draft, citing **verify.py:863** and **:990** at 27809ce; it is done.

13.2 Outstanding

- **Bind acc to its own evidence**. Reported by the auditor on 18 August 2026 and reproduced here. The specification never ties a series point’s **acc** to its **fails** vector, and **verify.py:1242** enforces the relation only for the **mock:*** control series. For every real series the declared accuracy is bound to no evidence at all. In **fixtures/valid** the series **beta:b1** declares 0.66 and 0.9 where its own **fails** vectors imply materially lower values, while **alpha:a1** and **gamma:g1** happen to be consistent. This is the closure rule of Section 7.6 one level down: there

an artifact was listed but unread, here a field is read but unbound. It sits inside the bundle this paper calls valid, and the verifier scoring 1.000 on the operator of Section 6 accepts it.

- **Close the symlink escape, reported after this study closed.** Pull request 8, open at the time of writing, reports that a covered artifact replaced by a symlink pointing outside the bundle exits 0 and prints `structural verification: PASS`. The bytes hash identically because they are the same bytes; they live somewhere else on the verifying host. That is a fifth vacuous pass against the hardened verifier, of the same class as Section 5 and outside the refusal-site population every number in this paper is measured over. It is deliberately not landed here: it changes `vac/verify.py`, and therefore the site count, the score, and every figure pinned to 92e4548. Landing it belongs to the next measurement, not to this one, and saying so is cheaper than a paper whose numbers quietly stopped matching its own repository.
- **Fix the CI issuer-checkout paths** so the env values do not compose to a doubled `vac/vac` directory, and add a hard assertion that no test skips with the reason “issuer checkout not present”, so a path that silently resolves to nothing fails loudly instead of measuring a smaller suite. See Section 9, item 7.
- **Re-emit the drifted issuer bundles** so the registry and the suite are green again (Section 7.6).
- **Get one external issuer.** Five same-author repositories are one fixture, not five issuers. A single outsider who builds a bundle from their own workflow, hits a real refusal or a specification ambiguity, and either lands or publishes the blocker is worth more than any further internal profile.
- **Climb the coverage ladder:** artifact-read (done) to field-binding (probed, gaps recorded) to claim coverage, where every externally visible claim names its evidence source and the verifier’s obligation over it.
- **Pre-register a second operator family** before running it: comparison inversion, boundary shifts, missing-key guard removal, enum and default perturbation, so the result is not chosen after seeing the score.
- **Cross-platform determinism in CI** (Linux, macOS, Windows), at minimum locale, encoding and path semantics. The encoding bug in Section 2.2 was found by a stranger, not by me.
- **Derive tamper fixtures from a published attack taxonomy** [32] rather than from imagination, since a threat model cannot contain its own blind spot.
- **Land the robustness pull request.** It is open and has been reworked in response to a revert. The reverted version built two fixtures with `json.loads('{{"a":' * 3000))`, which raises `RecursionError` inside the *decoder* before the verifier is called, so the tests were green on one interpreter and red on another: the same host-dependence class the patch exists to remove. At ce462e10, the head of the pull request on 2026-08-18 and resolvable only through `git fetch origin pull/2/head` because the branch sits on a fork, those tests build their structure in Python instead, and both issuer-data traversals are iterative with explicit stacks, so the stated blocker is met by the pull request itself. The head carries a date because it moved during drafting: the earlier bb4dda36, which this bullet named first, still asserted a wall-clock bound on elapsed time, an instance of the same host-dependence class; ce462e10

drops that assertion and leaves `vac/` byte-identical. What remains is review and merge. An earlier draft of this paper still described the blocker as open, having been written against a stale reading of the branch; that is instrument failure 4 recurring inside the paper's own outstanding-work list, which is why it is corrected here in place rather than dropped.

- **Pin the refusal-site population** the way `EXCLUDE` pins its arity, so a refactor that merges refusal sites aborts the sweep instead of shrinking the denominator (Section 6.4). Written rather than outlined: `tools/mutation_sweep.py` now declares `EXPECT_RAW_SITES` and `EXPECT_SCORED_SITES` and aborts with exit 2 when the measured population differs, with `--expect-sites` for a deliberate measurement at another revision. The gate was checked by declaring a population one smaller than the source carries and confirming the run aborts, rather than by assuming a written constant is an enforced one. Landed at `e932868`.
- **Commit the standalone-detector mode** used for the 10/112 figure in Section 7.1. *Done.* `tools/mutation_sweep.py` takes `--detector` and `tools/fixture_corpus_score.py` scores the corpus at `f59fb62`, where the sweep does not exist; both landed at `e932868`, and `fixtures/attack-crashkit-severity` (Table 4) at `b30ea2f`. Every disjunct of the kill predicate can now be scored on its own from a clone. This bullet is kept rather than deleted because an earlier draft of it promised work that did not exist, and the correction is more useful to a reader than a tidy list.

14 Conclusion

I asked four questions of one verifier and got four answers. Two thirds of its refusal sites could be deleted with every gate still green (RQ1: 75 of 112, score 0.330). Regression testing the four defects an external audit and a day of manual search had produced left the caught set on those 112 sites at exactly 37, and installed seven new refusals covered at 2/7 (RQ2). Writing one liveness test per surviving refusal took the score to 112/119, and covering the remainder reached 1.000 against this operator, though the size of that second move is partly entailed by defining the intervention in the metric's own units (RQ3). The operator's survivor classification anticipated three of the four hand-found forgeries and was blind to the fourth for a reason that is a property of the operator family, not of the run (RQ4).

The number I would most like a reader to take is not 1.000. It is 0.089. That is what the sixteen-`fixture` corpus behind the continuous-integration job named `invalidation-liveness`, whose stated purpose is to prove the verifier can refuse, scores as a detector standing on its own: 10 of 112. Measured the way the sweep actually runs it, downstream of a unit suite that already asserts every `fixture`'s exact verdict, its marginal contribution is a flat 0, and that 0 is arithmetic rather than misfortune. Either number says the same thing. A corpus sized at one `fixture` per imagined attack cannot cover a refusal population seven times its size, and a gate that has never been observed failing has not been observed working. I built the gate to observe failure and never asked it to observe most of them.

The single thing that would most change the picture is not another operator or another metric. It is one external issuer: somebody who is not me, building a bundle from their own workflow, hitting a refusal I did not anticipate.

Acknowledgements

Giulio D’Erme ran the audit that started this, in four public pull requests against the artifact repository. The four findings his first review did not reach were only findable because that review taught me the shape to look for; the encoding defect he found was one I had no route to discovering alone; and the symlink case recorded in Section 2.2 is his as well, found after the hardening, in the class this paper is about. Any errors that remain are mine, including, on the evidence of Section 9, some I have not yet detected.

Reproducibility and artifacts

The verifier, the specification, the mutation sweep, the fixture corpus, the registry, and the archived sweep outputs are public under the MIT licence at <https://github.com/egnaro9/vac-protocol>.

The state of that repository at the time of writing is archived and citable: **DOI 10.5281/zenodo.22000911**, which resolves to the most recent archived release. Release v0.1.0, deposited 2026-08-18 and built from commit 11291be, carries its own version DOI 10.5281/zenodo.22000912. Cite the version DOI to pin a number in this paper to the exact code that produced it; the concept DOI is for the project rather than for a result. Every quantitative claim here names a commit for the same reason: a result belongs to the code that produced it, not to whatever `main` holds later.

Commits. Check out 92e4548 for every present-day figure in this paper. The pre-fix baseline for Section 5 and the 0.330 measurement is f59fb62. The intermediate ladder rows in Table 2 name their own commits. Two line citations in the earlier draft’s fix list resolve only at 27809ce, which is noted where they appear.

Environment. Python 3.11 and 3.12 (the versions the project’s CI matrix uses). Install with `pip install -e ".[test]"`. Clone with `core.autocrlf` disabled: at 92e4548 the repository carries no `.gitattributes`, and a checkout that rewrites line endings makes the commands below fail, or worse, refuse for the wrong reason. The last paragraph of this section records what that costs, because it is not a footnote.

Commands.

```
python -m pytest tests/ -q                # 258 collected at 92e4548
python -m vac.verify fixtures/valid        # liveness control, exits 0
for d in fixtures/tamper-*; do \
    python -m vac.verify "$d"; done        # each exits 1
python tools/mutation_sweep.py --floor 0.99 --json out.json
grep -cE '^[[:space:]]*(f|failures)\.append\(' vac/verify.py # 146
```

Reproducing the four forgeries. Each is pinned by a committed fixture, and all four are now one command in both directions. The third reaches its pre-fix direction through a second fixture, which the caption names along with the one condition still attached to it.

A warning that is itself a finding. Reproduction is host-dependent. Fourteen tests are gated on sibling issuer checkouts, and `vac/registry.py` names five variables, not the three the workflow sets: `VAC_CRASHKIT_CHECKOUT`, `VAC_EVALMUT_CHECKOUT`, `VAC_MODELDRIFT_CHECKOUT`, `VAC_CERT-LAB_CHECKOUT` and `VAC_FLEET_CHECKOUT`, each pointing at a repository *root*, since the consumers

Table 4: Forgery to fixture mapping. Each fixture exits 1 at 92e4548 with the named reason. Copied into an f59fb62 checkout, the first, second and fourth exit 0, which is the pre-fix forgery reproduced in one command. The third takes a second fixture: `tamper-crashkit-severity` re-cases three severities but leaves `vulnerability_score` declared at the honest 0.4545, so the pre-fix verifier refuses it on the ordinary `raw-aggregate-mismatch` path, and it pins the post-fix refusal only. `fixtures/attack-crashkit-severity` completes the forgery: the same three re-casings, with 0.0 declared in `metrics.vulnerability_score`, in `results.summary.crash_vulnerability` and in the `crashkit-battery-v1` check’s `expect` block, and `evidence/eval_run.json` re-pinned honestly. It exits 0 at f59fb62 and exits 1 at 92e4548 on `artifact-unparsable`, both re-measured on 2026-08-18 against a liveness control that passes at each revision. That fifth fixture landed at b30ea2f, two commits after 92e4548, so it is absent from both revisions named here and has to be copied into a checkout of either; from b30ea2f onward, including the archived v0.1.0, it is present in a clean checkout, with `vac/` unchanged across that span (Section 13.2).

Section	Fixture	Refusal reason at 92e4548
5.1	<code>fixtures/tamper-summary-string</code>	<code>summary-outruns-checks</code>
5.2	<code>fixtures/tamper-check-deleted</code>	<code>evidence-unchecked</code>
5.3	<code>fixtures/tamper-crashkit-severity</code>	<code>artifact-unparsable</code>
5.4	<code>fixtures/tamper-stamp-deleted</code>	<code>stamp-mismatch</code>

append `/vac` themselves. With none of them bound the suite runs 238 passed, 16 skipped, 4 xfailed; with all five it runs 14 more. Binding only the first three runs 6 more, not 14, and nothing in the output says so, which is item 7 of Section 9 in a second costume: a checkout variable that resolves to nothing measures a smaller suite quietly. At the time of writing two of the issuer bundles fail, and both are issuer drift. `model-drift` fails identically at f59fb62 and at 92e4548 on the same bundle bytes, so no change in the verifier accounts for it. `evalmut` passes at f59fb62 and fails at 92e4548 on `evidence-unchecked`, a refusal that does not exist in the f59fb62 source, which reads like verifier tightening until the baseline is chosen correctly. f59fb62 predates that rule entirely. The commit that matters is ba14203, the 2026-08-16 state at which `evalmut` last landed clean: the rule is already present there, and `git log ba14203..92e4548 vac/verify.py` is empty, so the verifier has not moved since. Measured against that baseline `evalmut` is bundle drift too, which is what Section 7.6 reports. Either way the baseline is red and the mutation sweep aborts by design. The 143/143 figure is therefore reproducible on a checkout *without* the sibling repositories, which is how CI measures it and how I re-measured it on 2026-08-18.

A default Windows clone breaks this reproduction, and lies about how. The commands above assume a checkout that preserves bytes. At 92e4548 the repository carries no `.gitattributes` (`git ls-tree 92e4548 .gitattributes` is empty), while `core.autocrlf` is enabled by default by the Git for Windows installer, so a clone made there rewrites every text artifact to CRLF at checkout and the manifests go on hashing raw bytes. Measured on a differential pair of clones at 92e4548 differing only in `core.autocrlf`: all fourteen files under `fixtures/valid` carry CR in the enabled arm and none do in the disabled arm, and the liveness control exits 1 with thirteen `sha256-mismatch` reasons rather than exiting 0. Thirteen is the ceiling for this bundle, since `fixtures/valid` lists thirteen evidence entries and `vac.json` is not its own evidence.

The second half is this paper’s own thesis, occurring inside its reproduction section. All twenty `tamper-*` fixtures still exit 1 on that clone, so the loop above still passes and reports nothing wrong. But fourteen of the twenty no longer produce the refusal they were written to demonstrate: the

hash mismatch fires and the original reason is gone. Three of Table 4’s four rows name a reason the verifier no longer gives, with every exit code that a reader would check still matching. Only `tamper-check-deleted` still emits `evidence-unchecked`, and it does so buried among fourteen reasons. A loop over exit codes is a check on the exit code and not on the refusal, and it stayed green through exactly the substitution this paper is about, in the section that tells a stranger how to confirm the paper.

The checkout defect was filed as pull request 9 and merged at `81f50cf`, which adds a one-line `.gitattributes (* -text)`; re-measuring the same differential pair at that commit gives exit 0 in both arms. That fix does not reach the artifacts this paper pins. It is absent at `92e4548`, the commit every figure here is measured at, and absent from the `v0.1.0` archive (`git ls-tree v0.1.0 .gitattributes` is empty). Until those are re-pinned, disabling `core.autocrlf` at clone time is the only thing between a reader and a verifier that refuses honest bundles and misnames dishonest ones. I did not find the checkout defect; it was found by someone cloning the repository the way a stranger would, which is the only way it was ever going to be found from a project whose nine CI jobs all run `ubuntu-latest`. The second half, that the tamper loop keeps passing while the reasons change underneath it, surfaced only on re-running that loop on such a clone and reading the reasons instead of the exit codes.

Archived measurements. The sweep outputs backing Table 2 are committed under `paper/` as JSON: `mutation.json` (37/112), `mutation_after.json` (39/119), `mutation_covered.json` (112/119), `mutation_final2.json` (126/133), and `mutation_v8.json` (143/143). Seven further sweeps are archived in the same directory and are the source of the non-monotone record in Section 7.5: `mutation_gated.json` (39/119), `mutation_final.json` (112/117), `mutation_v2.json` (120/125), `mutation_v3.json` (123/129), `mutation_v5.json` (130/131), `mutation_v6.json` (131/131) and `mutation_v7.json` (139/143). Each file’s introducing commit is recoverable with `git log --diff-filter=A -- paper/<file>`, which is how the fourth row of Table 2 was pinned.

The standalone fixture-corpus score. The 10/112 in Section 7.1 is not one of the archived sweeps, and it is not produced by `tools/mutation_sweep.py`. It is produced by a second script, committed at `e932868`, in one command:

```
python tools/fixture_corpus_score.py # 10/112 = 0.089
python tools/fixture_corpus_score.py --detector liveness # 0/112 = 0.000
```

The script creates and removes its own detached worktree at `f59fb62`, refuses to run against a checkout sitting at any other revision or carrying uncommitted changes, and applies the same operator over the same `span()` logic, imported from `tools/mutation_sweep.py` rather than copied. Only the sixteen `tamper-*` directories may report a catch, and the ten catches are credited to ten distinct fixtures. The second line scores the clean-bundle control the same way and catches nothing, so none of the ten is borrowed from it. The second script is necessary rather than untidy: `mutation_sweep.py` now takes `--detector fixtures`, which is the right way to ask this of the tree as it stands, but that file does not exist at `f59fb62`, and pointing HEAD’s copy at a checkout of it aborts by design, since its `EXCLUDE` map is keyed to HEAD’s source and the arity guard refuses to resize the denominator rather than quietly measure a different one. Both the script and the `--detector` flag landed at `e932868` (Section 13.2), so this figure is re-runnable in one command from a clone rather than only on the author’s tree. Both numbers above were re-measured on 2026-08-18 from a fresh clone of the public repository.

References

- [1] Amit Seal Ami, Kaushal Kafle, Kevin Moran, Adwait Nadkarni, and Denys Poshyvanyk. Systematic mutation-based evaluation of the soundness of security-focused Android static analysis techniques. *ACM Transactions on Privacy and Security*, 24(3):1–37, 2021. Article 15. <https://doi.org/10.1145/3439802>.
- [2] Amit Seal Ami, Nathan Cooper, Kaushal Kafle, Kevin Moran, Denys Poshyvanyk, and Adwait Nadkarni. Why crypto-detectors fail: A systematic evaluation of cryptographic misuse detection techniques. In *2022 IEEE Symposium on Security and Privacy (SP)*, pages 614–631. IEEE, 2022. <https://doi.org/10.1109/SP46214.2022.9833582>. The preprint arXiv:2107.07065 now serves the extended ACM TOPS 2026 version, under a different title and a different author list, with 19 operators, 107 misuse cases and five additional detectors; the figures cited here are the 2022 conference version’s.
- [3] Amit Seal Ami, Syed Yusuf Ahmed, Radowan Mahmud Redoy, Nathan Cooper, Kaushal Kafle, Kevin Moran, Denys Poshyvanyk, and Adwait Nadkarni. MASC: A tool for mutation-based evaluation of static crypto-API misuse detectors. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE 2023)*, pages 2162–2166. ACM, 2023. Tool demonstration. <https://doi.org/10.1145/3611643.3613099>. Preprint arXiv:2308.02310.
- [4] Earl T. Barr, Mark Harman, Phil McMinn, Muzammil Shahbaz, and Shin Yoo. The oracle problem in software testing: A survey. *IEEE Transactions on Software Engineering*, 41(5): 507–525, 2015. <https://doi.org/10.1109/TSE.2014.2372785>.
- [5] Ilan Beer, Shoham Ben-David, Cindy Eisner, and Yoav Rodeh. Efficient detection of vacuity in temporal model checking. *Formal Methods in System Design*, 18(2):141–163, 2001. <https://doi.org/10.1023/A:1008779610539>.
- [6] Stella Biderman, Hailey Schoelkopf, Lintang Sutawika, Leo Gao, Jonathan Tow, et al. Lessons from the trenches on reproducible evaluation of language models. arXiv preprint arXiv:2405.14782, 2024. <https://arxiv.org/abs/2405.14782>.
- [7] Muhammad Bilal and Ali Hassaan Mughal. All green, still broken: Real-flow verification lessons from an LLM-integrated, multi-market web application. arXiv preprint arXiv:2606.22475, 2026. Preprint submitted to IEEE Software, 21 June 2026. <https://arxiv.org/abs/2606.22475>.
- [8] Henk Birkholz, Dave Thaler, Michael Richardson, Ned Smith, and Wei Pan. Remote ATtestation procedures (RATS) architecture. RFC 9334, Internet Engineering Task Force, 2023. <https://www.rfc-editor.org/rfc/rfc9334.html>.
- [9] Chad Brubaker, Suman Jana, Baishakhi Ray, Sarfraz Khurshid, and Vitaly Shmatikov. Using frankencerts for automated adversarial testing of certificate validation in SSL/TLS implementations. In *2014 IEEE Symposium on Security and Privacy (SP)*, pages 114–129. IEEE, 2014. <https://doi.org/10.1109/SP.2014.15>.
- [10] Timothy A. Budd, Richard A. DeMillo, Richard J. Lipton, and Frederick G. Sayward. Theoretical and empirical studies on using program mutation to test the functional correctness of programs. In *Proceedings of the 7th ACM SIGPLAN-SIGACT Symposium on Principles*

- of *Programming Languages (POPL '80)*, pages 220–233. ACM, 1980. <https://doi.org/10.1145/567446.567468>.
- [11] Yuting Chen and Carlo A. Furia. Robustness testing of intermediate verifiers. In *Automated Technology for Verification and Analysis (ATVA 2018)*, volume 11138 of *Lecture Notes in Computer Science*, pages 91–108. Springer, 2018. https://doi.org/10.1007/978-3-030-01090-4_6.
 - [12] Kevin Delcourt, Meriem Ben Chaaben, Abdelhamid Rouatbi, Luciano Marchezan, and Houari Sahraoui. Breaking models to test the judge: A mutation testing approach for semantic evaluators of domain class diagrams. In *Proceedings of the ACM/IEEE 29th International Conference on Model Driven Engineering Languages and Systems (MODELS)*. ACM, 2026. <https://arxiv.org/abs/2608.14315>, submitted 14 August 2026. To appear at MODELS 2026, Malaga, Spain. The ACM DOI is not yet registered in Crossref, and the value printed in the paper differs from the value in its own arXiv record, so no DOI is given here.
 - [13] Richard A. DeMillo, Richard J. Lipton, and Frederick G. Sayward. Hints on test data selection: Help for the practicing programmer. *Computer*, 11(4):34–41, 1978. <https://doi.org/10.1109/C-M.1978.218136>.
 - [14] Lin Deng, Jeff Offutt, and Nan Li. Empirical evaluation of the statement deletion mutation operator. In *2013 IEEE Sixth International Conference on Software Testing, Verification and Validation (ICST 2013)*, pages 84–93. IEEE, 2013. <https://doi.org/10.1109/ICST.2013.20>.
 - [15] Giulio D’Erme. Comment on “I built an AI dev harness that isn’t allowed to trust itself”. DEV Community, 8 2026. URL <https://dev.to/agentdev9/comment/3d3lp>. Posted 2026-08-15T09:05:28Z, comment 3d3lp, under the account gde03. Reports the cca-audit deep-tier run, names the four findings the specification refuted, and records the mojobake incident.
 - [16] Giulio D’Erme. Refuse bundles that verify clean while their numbers are false. Pull request #1, [egnaro9/vac-protocol](https://github.com/egnaro9/vac-protocol), merged, 2026. URL <https://github.com/egnaro9/vac-protocol/pull/1>. The sentence quoted in Section 2 is from the pull request body, which is public on a public repository.
 - [17] Marcel Fourné, Dominik Wermke, William Enck, Sascha Fahl, and Yasemin Acar. It’s like flossing your teeth: On the importance and challenges of reproducible builds for software supply chain security. In *2023 IEEE Symposium on Security and Privacy (SP)*, pages 1527–1544. IEEE, 2023. <https://doi.org/10.1109/SP46215.2023.10179320>.
 - [18] Martin Georgiev, Subodh Iyengar, Suman Jana, Rishita Anubhai, Dan Boneh, and Vitaly Shmatikov. The most dangerous code in the world: validating SSL certificates in non-browser software. In *Proceedings of the 2012 ACM Conference on Computer and Communications Security (CCS '12)*, pages 38–49. ACM, 2012. <https://doi.org/10.1145/2382196.2382204>.
 - [19] Philipp Görz, Björn Mathis, Keno Hassler, Emre Güler, Thorsten Holz, Andreas Zeller, and Rahul Gopinath. Systematic assessment of fuzzers using mutation analysis. In *32nd USENIX Security Symposium (USENIX Security '23)*, pages 4535–4552. USENIX Association, 2023. <https://www.usenix.org/conference/usenixsecurity23/presentation/gorz>.
 - [20] Richard G. Hamlet. Testing programs with the aid of a compiler. *IEEE Transactions on Software Engineering*, SE-3(4):279–290, 1977. <https://doi.org/10.1109/TSE.1977.231145>.

- [21] Chen Huo and James Clause. Improving oracle quality by detecting brittle assertions and unused inputs in tests. In *Proceedings of the 22nd ACM SIGSOFT International Symposium on Foundations of Software Engineering (FSE 2014)*, pages 621–631. ACM, 2014. <https://doi.org/10.1145/2635868.2635917>.
- [22] in-toto project. in-toto specification, version 1.0.0. <https://github.com/in-toto/docs/blob/master/in-toto-spec.md>, 2023. Dated 2023-06-02. Accessed 2026-08-18.
- [23] in-toto project. Statement layer specification, in-toto attestation framework v1. <https://github.com/in-toto/attestation/blob/main/spec/v1/statement.md>, 2024. Accessed 2026-08-18.
- [24] Laura Inozemtseva and Reid Holmes. Coverage is not strongly correlated with test suite effectiveness. In *Proceedings of the 36th International Conference on Software Engineering (ICSE 2014)*, pages 435–445. ACM, 2014. <https://doi.org/10.1145/2568225.2568271>.
- [25] Gunel Jahangirova, David Clark, Mark Harman, and Paolo Tonella. Test oracle assessment and improvement. In *Proceedings of the 25th International Symposium on Software Testing and Analysis (ISSTA 2016)*, pages 247–258. ACM, 2016. <https://doi.org/10.1145/2931037.2931062>.
- [26] Changbing Ji, Zhenyu Chen, Baowen Xu, and Ziyuan Wang. A new mutation analysis method for testing Java exception handling. In *Proceedings of the 33rd Annual IEEE International Computer Software and Applications Conference (COMPSAC 2009)*, volume 2, pages 556–561. IEEE, 2009. <https://doi.org/10.1109/COMPSAC.2009.192>.
- [27] Yue Jia and Mark Harman. An analysis and survey of the development of mutation testing. *IEEE Transactions on Software Engineering*, 37(5):649–678, 2011. <https://doi.org/10.1109/TSE.2010.62>.
- [28] René Just, Darioush Jalali, Laura Inozemtseva, Michael D. Ernst, Reid Holmes, and Gordon Fraser. Are mutants a valid substitute for real faults in software testing? In *Proceedings of the 22nd ACM SIGSOFT International Symposium on Foundations of Software Engineering (FSE 2014)*, pages 654–665. ACM, 2014. <https://doi.org/10.1145/2635868.2635929>.
- [29] Kapil Kumar, P. K. Gupta, and Roshan Parjapat. New mutants generation for testing Java programs. In *Computer Networks and Information Technologies, Communications in Computer and Information Science*, pages 290–294. Springer Berlin Heidelberg, 2011. https://doi.org/10.1007/978-3-642-19542-6_50.
- [30] Orna Kupferman. Sanity checks in formal verification. In *CONCUR 2006, Concurrency Theory, Lecture Notes in Computer Science*, pages 37–51. Springer Berlin Heidelberg, 2006. https://doi.org/10.1007/11817949_3.
- [31] Orna Kupferman and Moshe Y. Vardi. Vacuity detection in temporal model checking. *International Journal on Software Tools for Technology Transfer*, 4(2):224–233, 2003. <https://doi.org/10.1007/s100090100062>.
- [32] Piergiorgio Ladisa, Henrik Plate, Matias Martinez, and Olivier Barais. SoK: Taxonomy of attacks on open-source software supply chains. In *2023 IEEE Symposium on Security and Privacy (SP)*, pages 1509–1526. IEEE, 2023. <https://doi.org/10.1109/SP46215.2023.10179304>.

- [33] Chris Lamb and Stefano Zacchiroli. Reproducible builds: Increasing the integrity of software supply chains. *IEEE Software*, 39(2):62–70, 2022. <https://doi.org/10.1109/MS.2021.3073045>.
- [34] Stephan Lipp, Sebastian Banescu, and Alexander Pretschner. An empirical study on the effectiveness of static C code analyzers for vulnerability detection. In *Proceedings of the 31st ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA 2022)*, pages 544–555. ACM, 2022. <https://doi.org/10.1145/3533767.3534380>.
- [35] Thomas Loise, Xavier Devroey, Gilles Perrouin, Mike Papadakis, and Patrick Heymans. Towards security-aware mutation testing. In *2017 IEEE International Conference on Software Testing, Verification and Validation Workshops (ICSTW 2017)*, pages 97–102. IEEE, 2017. <https://doi.org/10.1109/ICSTW.2017.24>.
- [36] Evan Martin and Tao Xie. A fault model and mutation testing of access control policies. In *Proceedings of the 16th International Conference on World Wide Web (WWW 2007)*, pages 667–676. ACM, 2007. <https://doi.org/10.1145/1242572.1242663>.
- [37] Megan Maton, Gregory M. Kapfhammer, and Phil McMinn. Exploring pseudo-testedness: Empirically evaluating extreme mutation testing at the statement level. In *2024 IEEE International Conference on Software Maintenance and Evolution (ICSME 2024)*, pages 587–598. IEEE, 2024. <https://doi.org/10.1109/ICSME58944.2024.00059>.
- [38] MITRE Corporation. CWE-1288: Improper validation of consistency within input. Common Weakness Enumeration, version 4.20. <https://cwe.mitre.org/data/definitions/1288.html>, 2026. Accessed 2026-08-18.
- [39] MITRE Corporation. CWE-390: Detection of error condition without action. Common Weakness Enumeration, version 4.20. <https://cwe.mitre.org/data/definitions/390.html>, 2026. Accessed 2026-08-18.
- [40] MITRE Corporation. CWE-636: Not failing securely (‘failing open’). Common Weakness Enumeration, version 4.20. <https://cwe.mitre.org/data/definitions/636.html>, 2026. Accessed 2026-08-18.
- [41] MITRE Corporation. CWE-703: Improper check or handling of exceptional conditions. Common Weakness Enumeration, version 4.20. <https://cwe.mitre.org/data/definitions/703.html>, 2026. Accessed 2026-08-18.
- [42] MITRE Corporation. CWE-754: Improper check for unusual or exceptional conditions. Common Weakness Enumeration, version 4.20. <https://cwe.mitre.org/data/definitions/754.html>, 2026. Accessed 2026-08-18.
- [43] Zachary Newman, John Speed Meyers, and Santiago Torres-Arias. Sigstore: Software signing for everybody. In *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security (CCS ’22)*, pages 2353–2367. ACM, 2022. <https://doi.org/10.1145/3548606.3560596>.
- [44] Rainer Niedermayr, Elmar Juergens, and Stefan Wagner. Will my tests tell me if i break this code? In *Proceedings of the International Workshop on Continuous Software Evolution and Delivery (CSED ’16)*, pages 23–29. ACM, 2016. <https://doi.org/10.1145/2896941.2896944>.

- [45] Jonathan Örgård, Gregory Gay, Francisco Gomes de Oliveira Neto, and Kim Viggedal. Mutation testing in continuous integration: An exploratory industrial case study. In *2023 IEEE International Conference on Software Testing, Verification and Validation Workshops (ICSTW 2023)*, pages 324–333. IEEE, 2023. <https://doi.org/10.1109/ICSTW58534.2023.00063>.
- [46] Mike Papadakis, Marinos Kintis, Jie Zhang, Yue Jia, Yves Le Traon, and Mark Harman. Mutation testing advances: An analysis and survey. In *Advances in Computers*, volume 112, pages 275–378. Elsevier, 2019. <https://doi.org/10.1016/bs.adcom.2018.03.015>.
- [47] Goran Petrović and Marko Ivanković. State of mutation testing at google. In *Proceedings of the 40th International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP 2018)*, pages 163–171. ACM, 2018. <https://doi.org/10.1145/3183519.3183521>.
- [48] pitest project. Frequently asked questions: My tests normally run green but PIT says the suite isn’t green. <https://pitest.org/faq/>, 2026. Accessed 2026-08-18.
- [49] Justin Samuel, Nick Mathewson, Justin Cappos, and Roger Dingledine. Survivable key compromise in software update systems. In *Proceedings of the 17th ACM Conference on Computer and Communications Security (CCS ’10)*, pages 61–72. ACM, 2010. <https://doi.org/10.1145/1866307.1866315>.
- [50] David Schuler and Andreas Zeller. Assessing oracle quality with checked coverage. In *2011 Fourth IEEE International Conference on Software Testing, Verification and Validation (ICST 2011)*, pages 90–99. IEEE, 2011. <https://doi.org/10.1109/ICST.2011.32>.
- [51] David Schuler and Andreas Zeller. Checked coverage: an indicator for oracle quality. *Software Testing, Verification and Reliability*, 23(7):531–551, 2013. <https://doi.org/10.1002/stvr.1497>.
- [52] sigstore/cosign maintainers. `cosign verify-attestation --type` can report a false positive if any attestation exists. GitHub Security Advisory GHSA-vjxv-45g9-9296, CVE-2022-35929. <https://github.com/sigstore/cosign/security/advisories/GHSA-vjxv-45g9-9296>, 2022. Affected: cosign < 1.10.1. Severity ratings diverge across sources: the advisory itself says Moderate, the GitHub CNA records CVSS 3.1 base 7.1 (High), and NVD scores the same CVE 9.8 (Critical). Accessed 2026-08-18.
- [53] Jocelyn Simmonds, Jessica Davies, Arie Gurfinkel, and Marsha Chechik. Exploiting resolution proofs to speed up LTL vacuity detection for BMC. *International Journal on Software Tools for Technology Transfer*, 12(5):319–335, 2010. <https://doi.org/10.1007/s10009-009-0134-1>.
- [54] SLSA project, Open Source Security Foundation. SLSA specification v1.2, build track: Verifying artifacts. <https://slsa.dev/spec/v1.2/verifying-artifacts>, 2025. Status: Approved. Accessed 2026-08-18.
- [55] Ken Thompson. Reflections on trusting trust. *Communications of the ACM*, 27(8):761–763, 1984. <https://doi.org/10.1145/358198.358210>.
- [56] Santiago Torres-Arias, Hammad Afzali, Trishank Karthik Kuppusamy, Reza Curtmola, and Justin Cappos. in-toto: Providing farm-to-table guarantees for bits and bytes. In *Proceedings of the 28th USENIX Security Symposium (USENIX Security ’19)*, pages 1393–1410. USENIX Association, 2019. <https://www.usenix.org/conference/usenixsecurity19/presentation/torres-arias>.

- [57] Roland H. Untch. On reduced neighborhood mutation analysis using a single mutagenic operator. In *Proceedings of the 47th Annual ACM Southeast Regional Conference (ACM-SE 47)*, pages 1–4. ACM, 2009. <https://doi.org/10.1145/1566445.1566540>.
- [58] Oscar Luis Vera-Pérez, Benjamin Danglot, Martin Monperrus, and Benoit Baudry. A comprehensive study of pseudo-tested methods. *Empirical Software Engineering*, 24(3):1195–1225, 2019. <https://doi.org/10.1007/s10664-018-9653-2>.
- [59] Elaine J. Weyuker. On testing non-testable programs. *The Computer Journal*, 25(4):465–470, 1982. <https://doi.org/10.1093/comjnl/25.4.465>.
- [60] Boming Xia, Tingting Bi, Zhenchang Xing, Qinghua Lu, and Liming Zhu. An empirical study on software bill of materials: Where we stand and the road ahead. In *Proceedings of the 45th IEEE/ACM International Conference on Software Engineering (ICSE 2023)*, pages 2630–2642. IEEE, 2023. <https://doi.org/10.1109/ICSE48619.2023.00219>.
- [61] Yucheng Zhang and Ali Mesbah. Assertions are strongly correlated with test suite effectiveness. In *Proceedings of the 2015 10th Joint Meeting on Foundations of Software Engineering (ESEC/FSE 2015)*, pages 214–224. ACM, 2015. <https://doi.org/10.1145/2786805.2786858>.
- [62] Zhimin Zhao, Abdul Ali Bangash, Filipe Roseiro Cogo, Bram Adams, and Ahmed E. Hassan. On the workflows and smells of leaderboard operations (LBOPs): An exploratory study of foundation model leaderboards. *IEEE Transactions on Software Engineering*, 51(4):929–946, 2025. <https://doi.org/10.1109/TSE.2025.3533972>.
- [63] Hong Zhu, Patrick A. V. Hall, and John H. R. May. Software unit test coverage and adequacy. *ACM Computing Surveys*, 29(4):366–427, 1997. <https://doi.org/10.1145/267580.267590>.